

Universidad
Mariana

TALLER AUDITORÍA WEB AVANZADA KALI - LINUX

Sarah Esther Calderón Legarda
Luna Alexandra Beltrán Escobar
Leidy Fernanda Eraso Vásquez

Universidad Mariana
Programa de Ingeniería de Sistemas
Seguridad en Sistemas
Noveno semestre
22 de octubre de 2026

Actividad

Realizar una auditoría de seguridad web en un entorno de laboratorio controlado mediante las herramientas ***FFUF, Burp Suite/Caido y JWT Tool***, con el propósito de identificar recursos expuestos, evaluar los controles de acceso y analizar la validación de tokens de autenticación.

La actividad comprende la ejecución de pruebas, la documentación de evidencias, la identificación y clasificación de posibles vulnerabilidades, y la formulación de medidas correctivas con su respectiva verificación.

Herramientas a utilizar:

- ***FFUF:*** Por sus siglas Fuzz Faster U Fool o "Fuzz más rápido, tonto", cumple la función del descubrimiento de directorios, archivos y rutas web.

  Fuzz: técnica de pruebas que introduce datos o palabras para descubrir comportamientos inesperados.

  Faster: más rápido.

  U Fool: forma informal de escribir you fool, que significa «tú, tonto».

  FFUF permite realizar pruebas de fuzzing sobre una aplicación web mediante diccionarios de palabras, con el fin de identificar rutas y recursos que no están enlazados directamente en la interfaz. En el proyecto, se utilizará para reconocer posibles recursos expuestos y analizar las respuestas HTTP del servidor, diferenciando los resultados relevantes de las respuestas genéricas.

- ***CAIDO:*** Cumple la función de realizar la ***inspección y análisis de solicitudes y respuestas HTTP.***

  Caido es una herramienta de pruebas de seguridad web que funciona como un proxy de interceptación, permitiendo observar e inspeccionar la comunicación entre el navegador y el servidor.

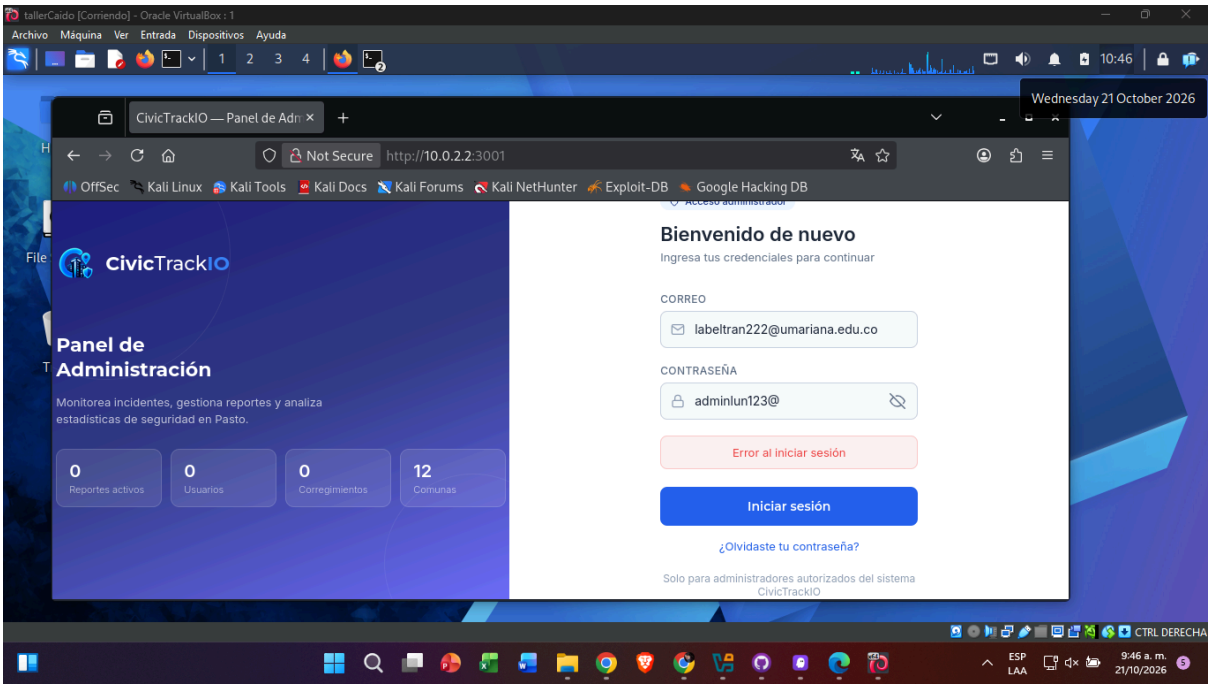
  En el proyecto, se utilizará para analizar las solicitudes HTTP, modificar parámetros de prueba y comprobar si el sistema aplica correctamente los permisos de acceso según el usuario y su rol. Esto ayudará a detectar posibles fallos de autorización, como el acceso a información sin los permisos correspondientes.

- ***JWT TOOL:*** Por sus siglas ***JSON Web Tokens***, este tiene la función de realizar el ***análisis de tokens de autenticación.***

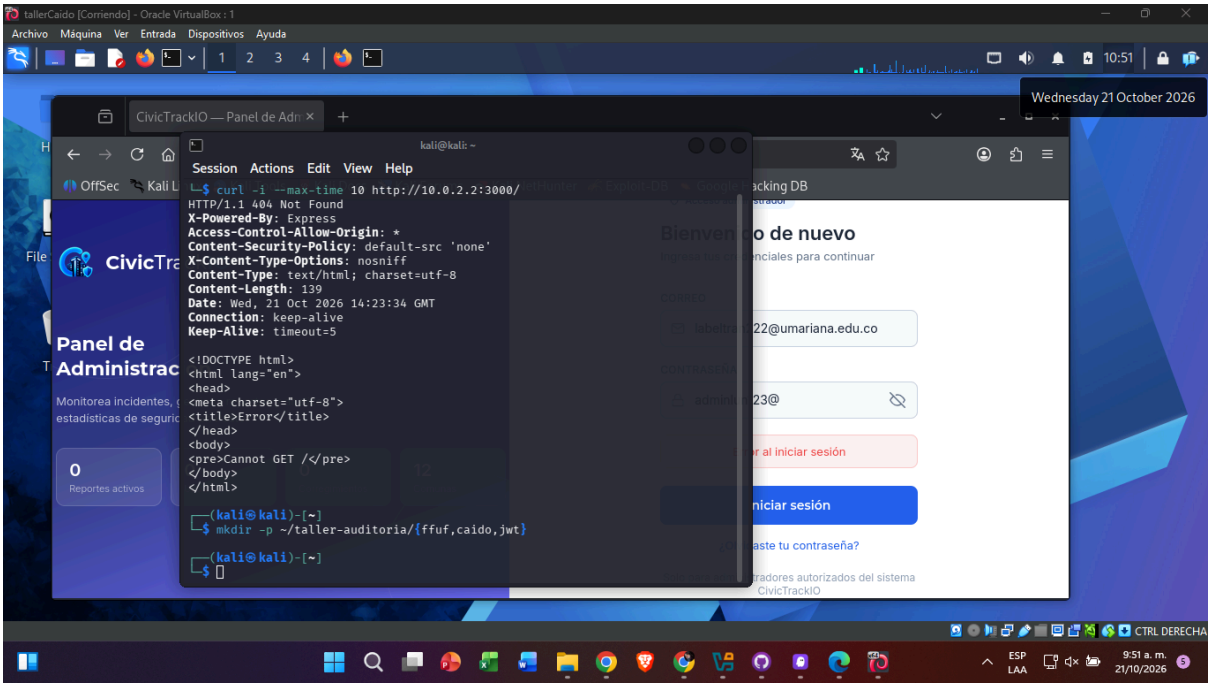
  JWT Tool permite examinar la estructura de los JSON Web Tokens (JWT), incluyendo su encabezado (header), contenido (payload) y firma (signature). En el proyecto, se utilizará para verificar qué información contienen los tokens de prueba y evaluar si el sistema valida correctamente su firma, expiración y demás atributos de seguridad. El objetivo es identificar posibles debilidades en el manejo de tokens que puedan afectar la autenticación y la integridad de las sesiones.

Desarrollo de actividad

Lo primero que se realiza es comprobar que desde dentro de la Máquina virtual de Kali-Linux no se nos permita acceder al sistema:

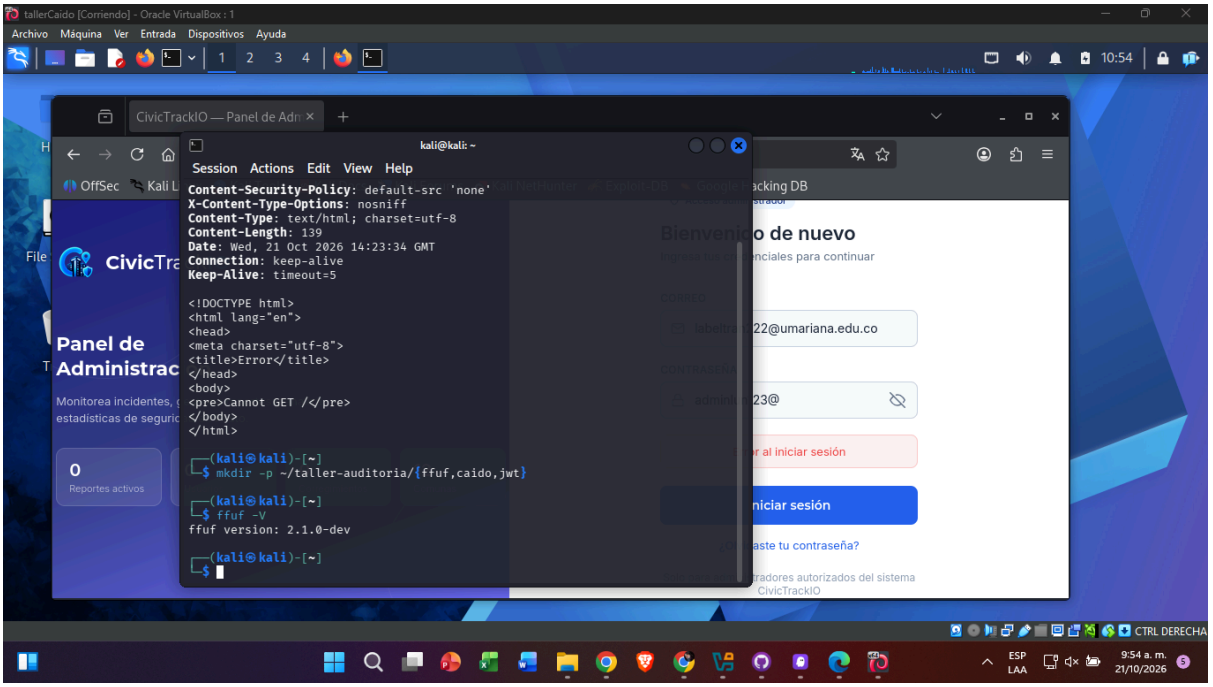


Ahora en la terminal de Kali creamos las carpetas para guardar el trabajo:

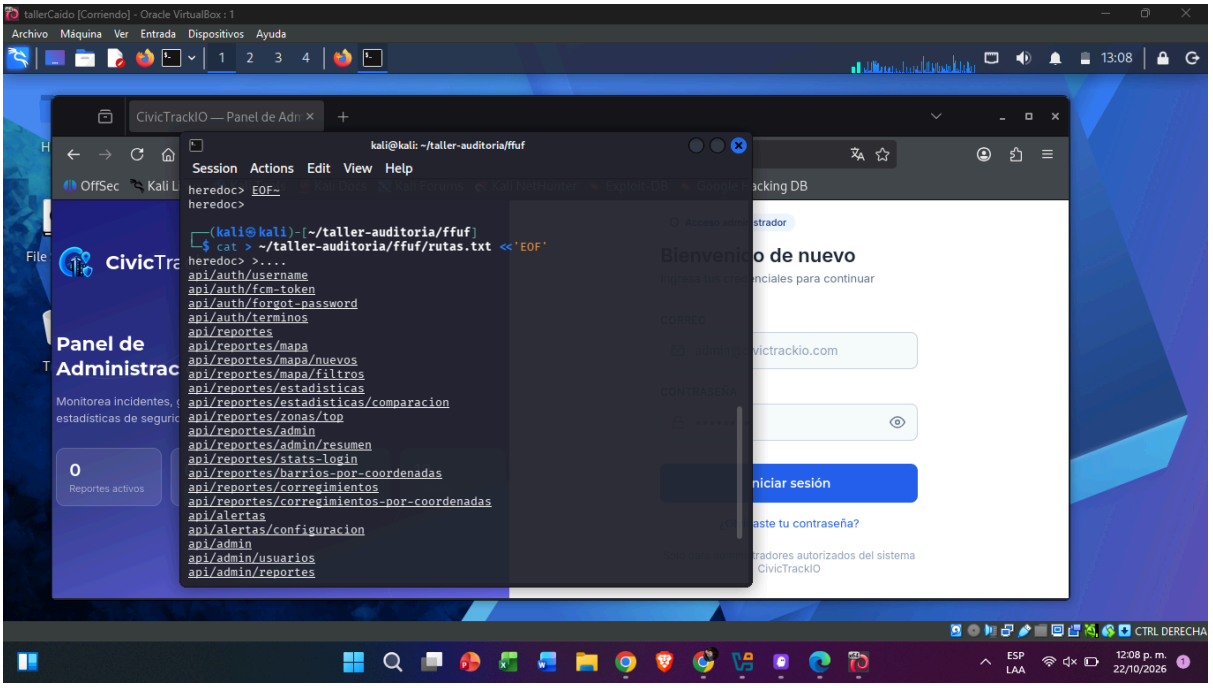


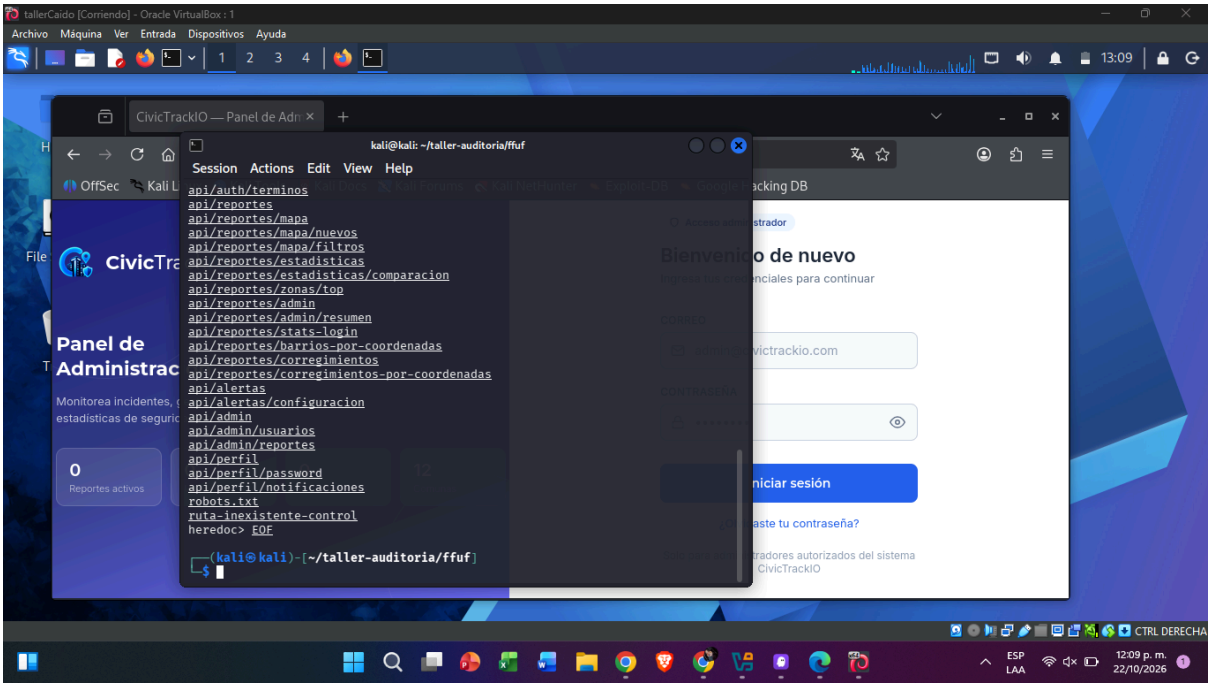
Pasamos al uso del primer comando que es el FFUF que nos sirve para identificar rutas, distinguir respuestas genéricas y confirmar manualmente los resultados. La presentación solicita clasificar tres rutas confirmadas y justificar su exposición.

Para comenzar, primero comprobamos que exista el acceso a FFUF:

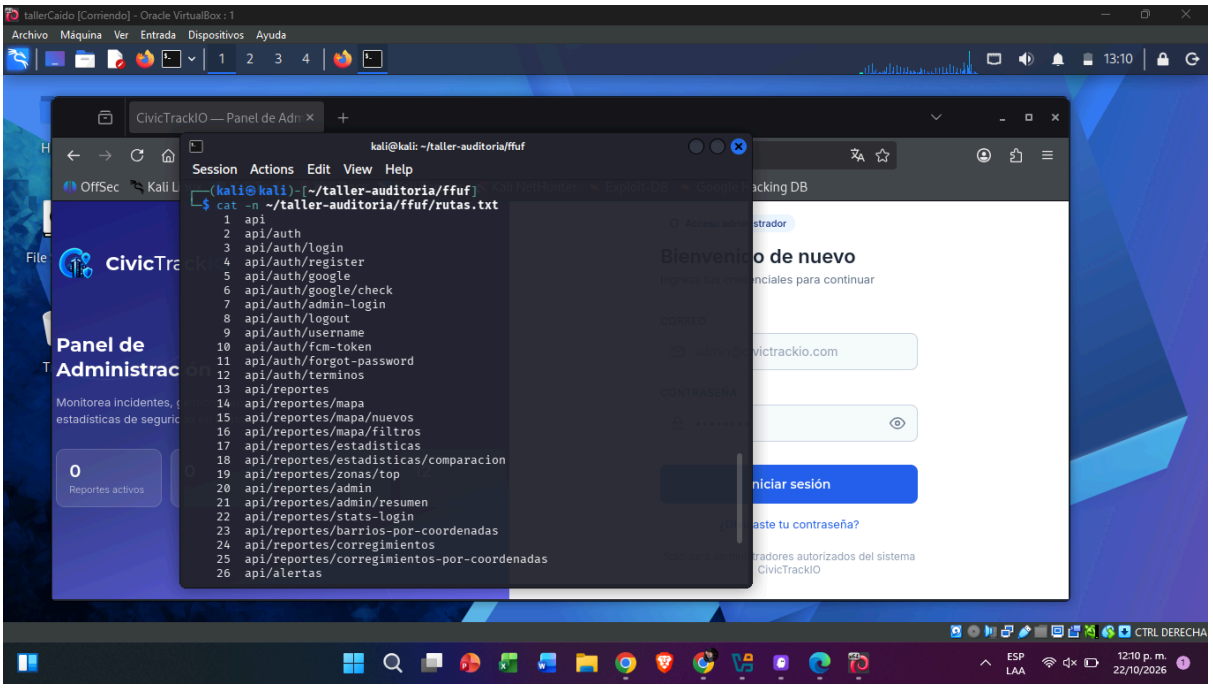


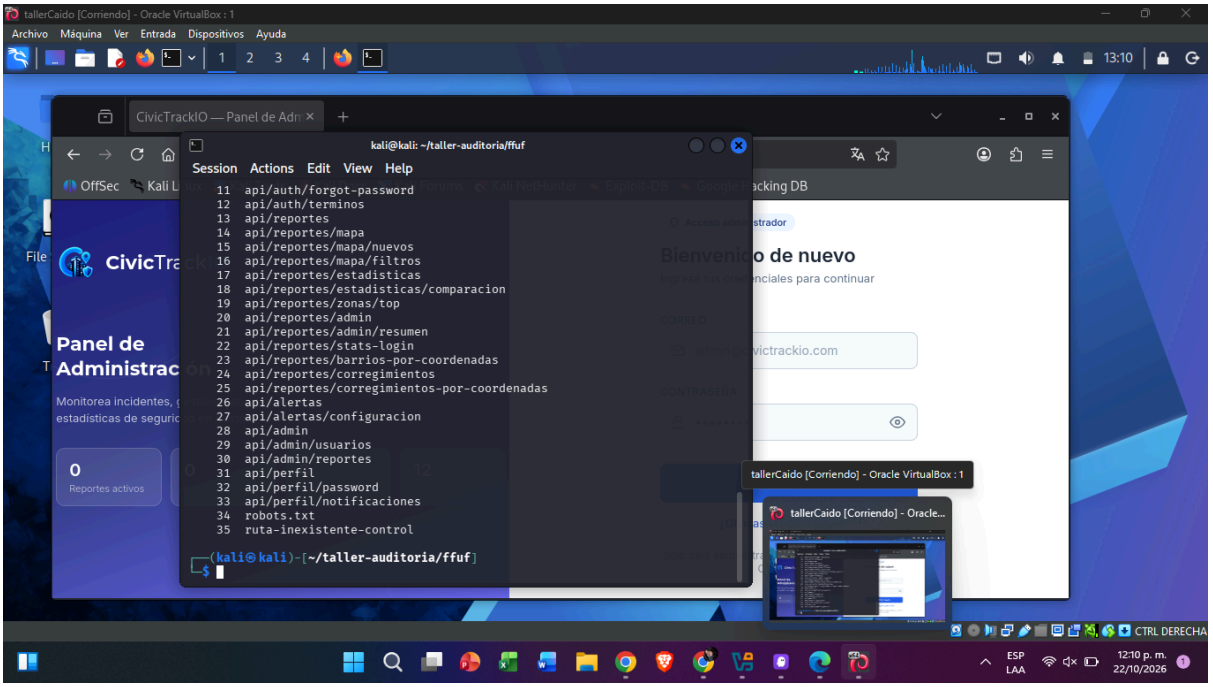
Posteriormente pasamos a la creación del diccionario, para eso nosotros buscamos las direcciones de nuestro proyecto y las colocamos en la terminal Kali.



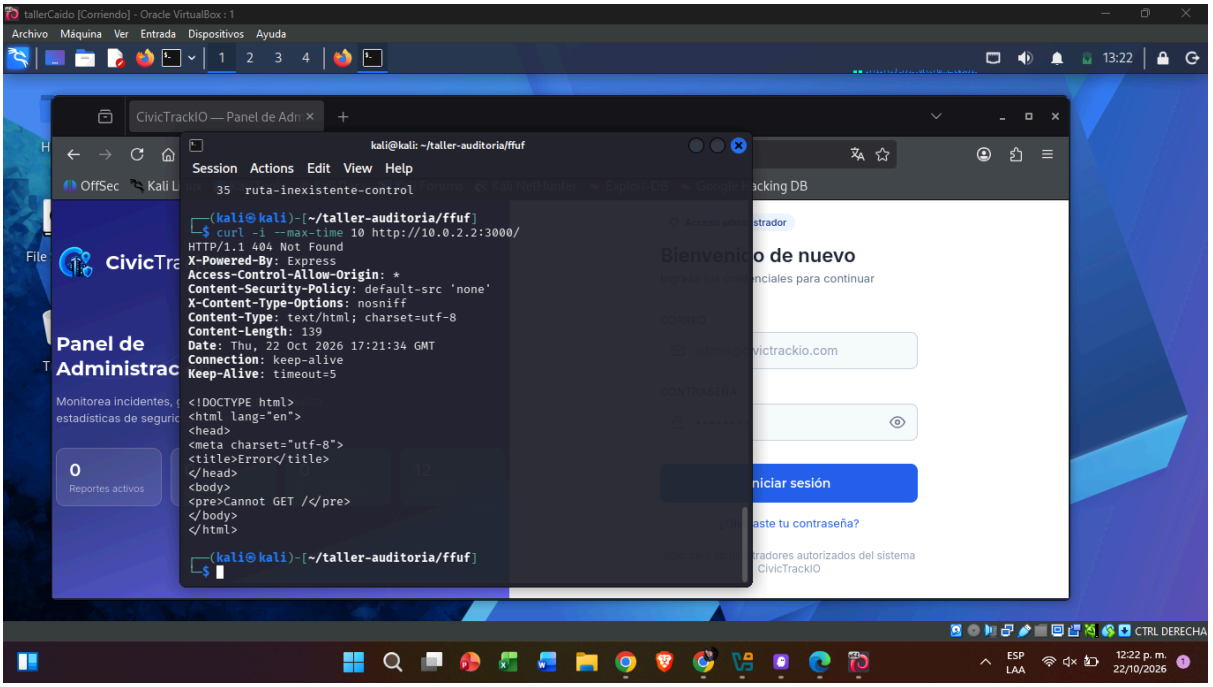


Ahora comprobamos que las rutas se hayan creado correctamente, debemos encontrar un total de 35 rutas numeradas correctamente.

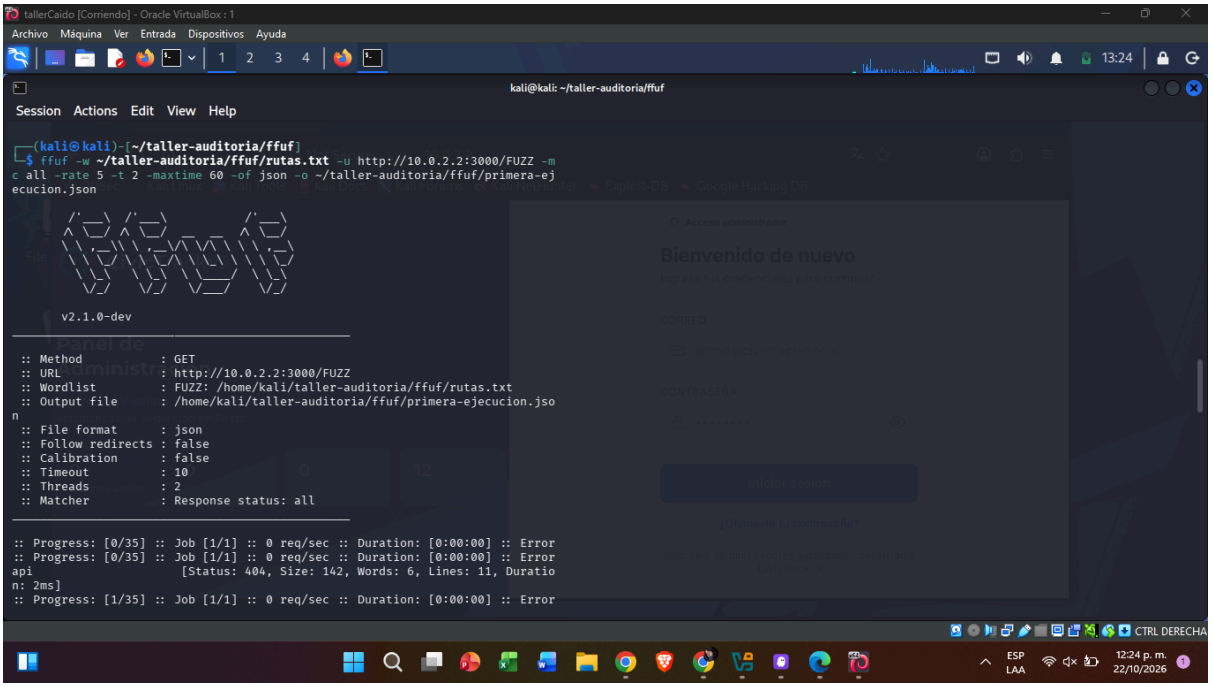


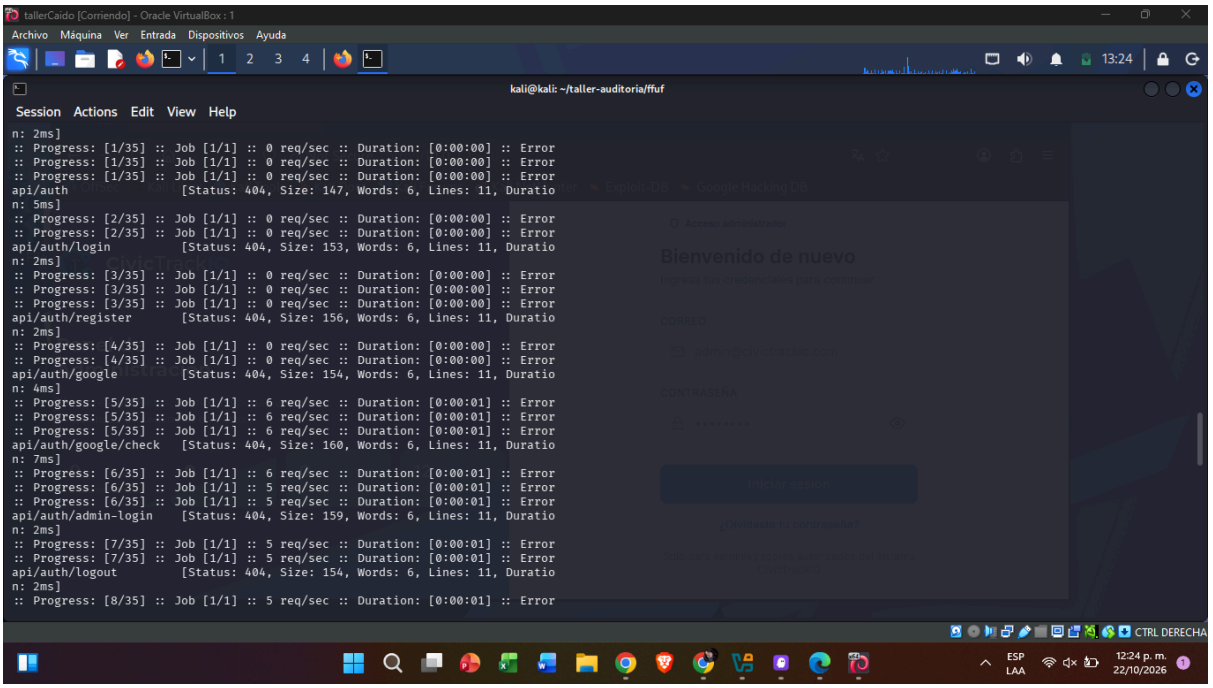


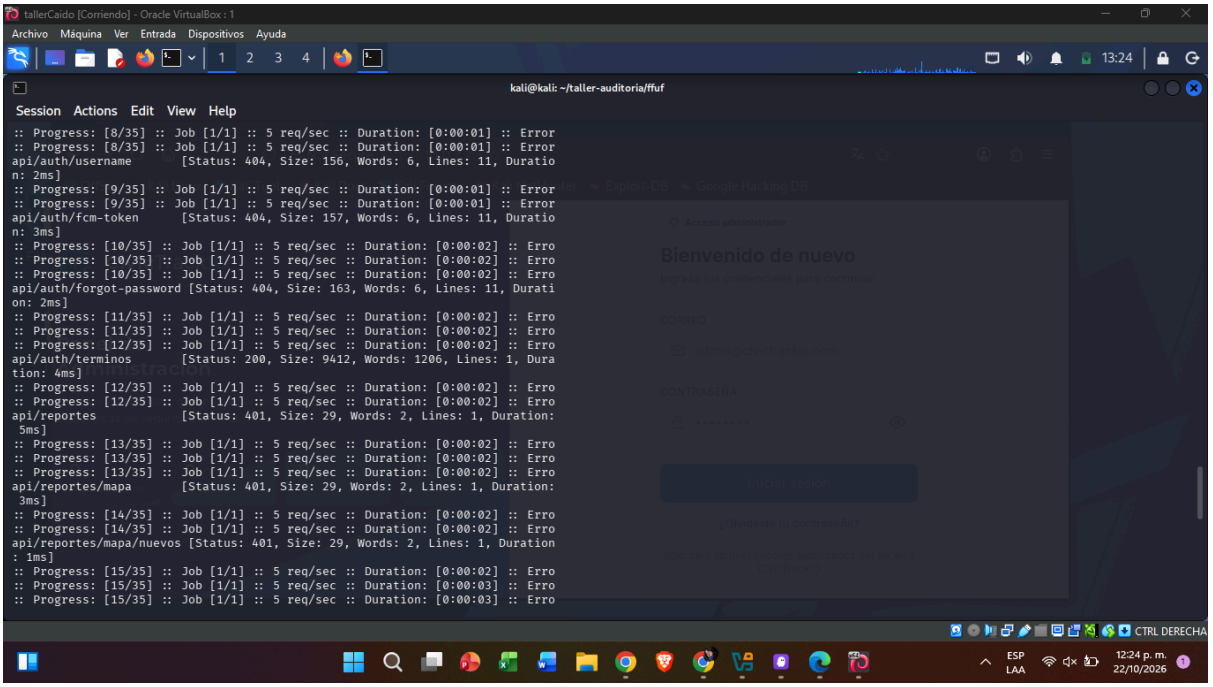
Ahora lo que hacemos es ejecutar la primera prueba con **FFUF**, guardar la salida y después analizar qué rutas responden, para ello lo primero que hacemos es comprobar que la conexión con el backend siga activa.

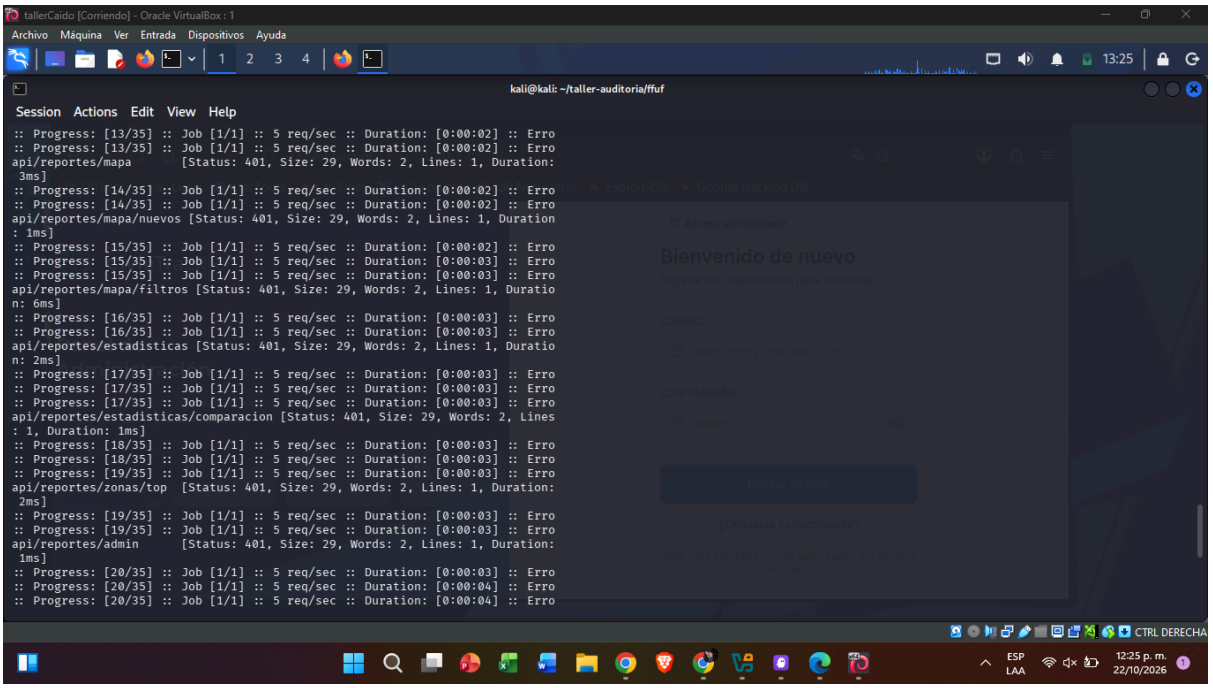


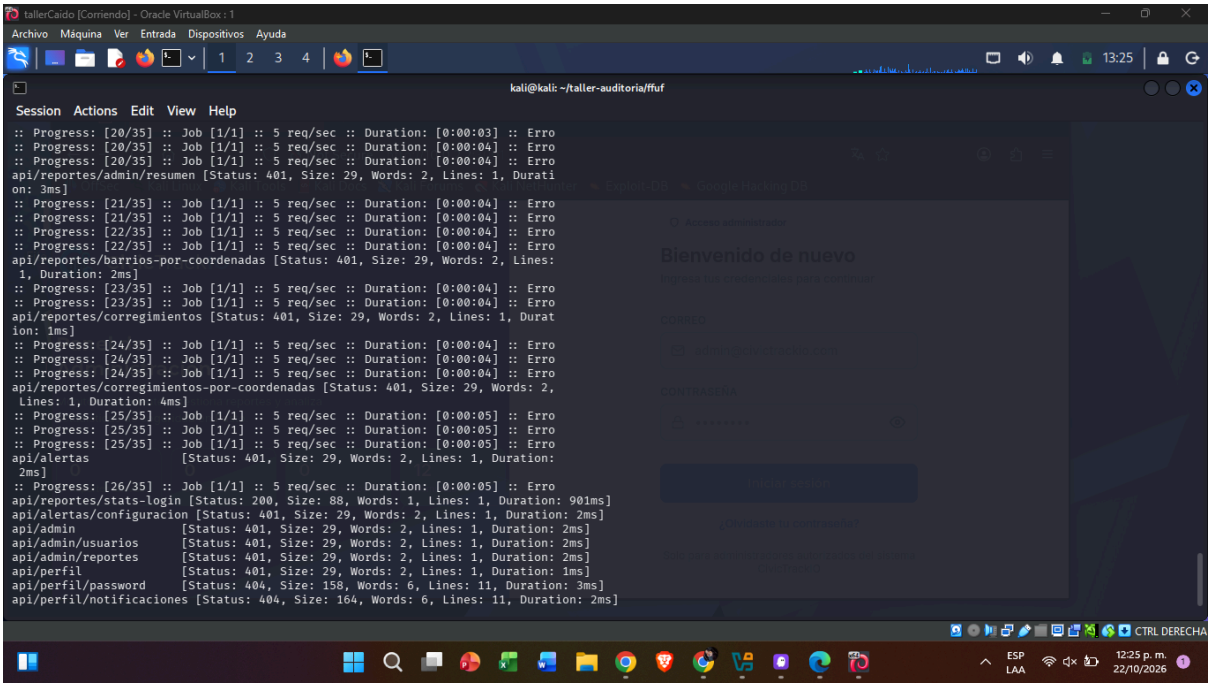
Ahora ejecutamos la primera prueba

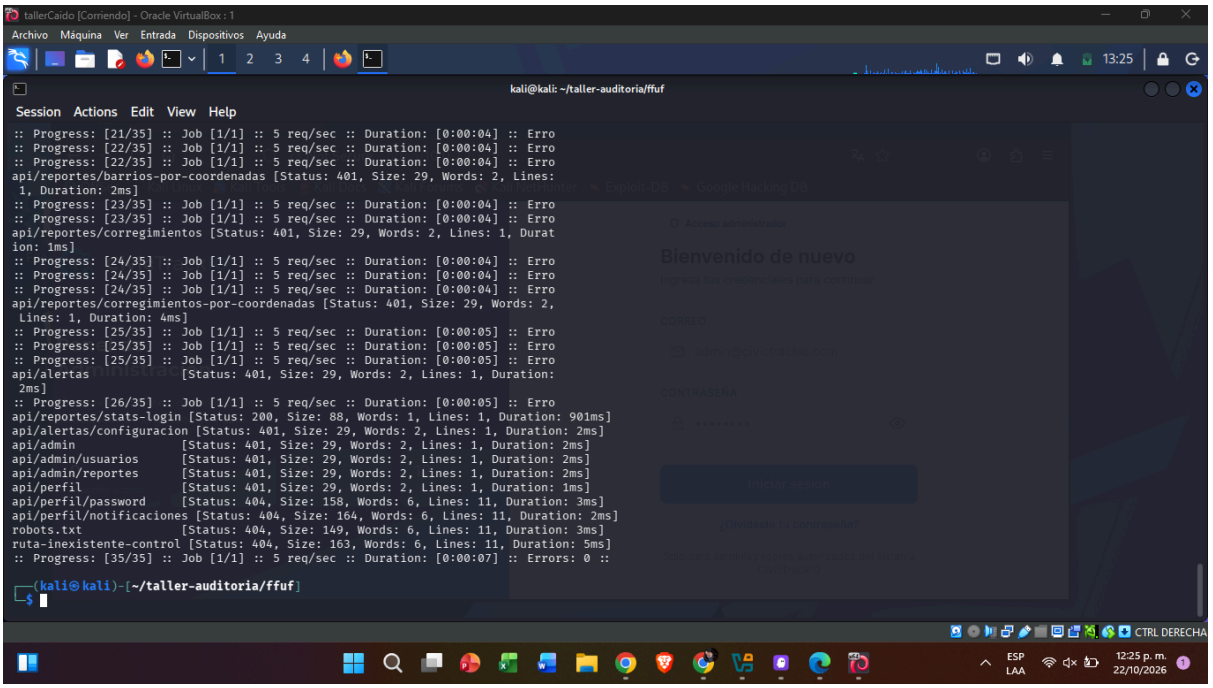

tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
kali@kali: ~/taller-auditoria/ffuf
Session Actions Edit View Help
┌──(kali㉿kali)-[~/taller-auditoria/ffuf]
└─$ ffuf -w ~/taller-auditoria/ffuf/rutas.txt -u http://10.0.2.2:3000/FUZZ -mc all -rate 5 -t 2 -maxtime 60 -of json -o ~/taller-auditoria/ffuf/primera-ejecucion.json
v2.1.0-dev
:: Method : GET
:: URL : http://10.0.2.2:3000/FUZZ
:: Wordlist : FUZZ: /home/kali/taller-auditoria/ffuf/rutas.txt
:: Output file : /home/kali/taller-auditoria/ffuf/primera-ejecucion.json
:: File format : json
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 2
:: Matcher : Response status: all
:: Progress: [0/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [0/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
api [Status: 404, Size: 142, Words: 6, Lines: 11, Duration: 2ms]
:: Progress: [1/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error


tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
kali@kali: ~/taller-auditoria/ffuf
Session Actions Edit View Help
:: Progress: [1/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [1/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [1/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
api/auth [Status: 404, Size: 147, Words: 6, Lines: 11, Duration: 5ms]
:: Progress: [2/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [2/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
api/auth/login [Status: 404, Size: 153, Words: 6, Lines: 11, Duration: 2ms]
:: Progress: [3/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [3/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [3/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
api/auth/register [Status: 404, Size: 156, Words: 6, Lines: 11, Duration: 2ms]
:: Progress: [4/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [4/35] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
api/auth/google [Status: 404, Size: 154, Words: 6, Lines: 11, Duration: 4ms]
:: Progress: [5/35] :: Job [1/1] :: 6 req/sec :: Duration: [0:00:01] :: Error
:: Progress: [5/35] :: Job [1/1] :: 6 req/sec :: Duration: [0:00:01] :: Error
:: Progress: [5/35] :: Job [1/1] :: 6 req/sec :: Duration: [0:00:01] :: Error
api/auth/google/check [Status: 404, Size: 160, Words: 6, Lines: 11, Duration: 7ms]
:: Progress: [6/35] :: Job [1/1] :: 6 req/sec :: Duration: [0:00:01] :: Error
:: Progress: [6/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:01] :: Error
:: Progress: [6/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:01] :: Error
api/auth/admin-login [Status: 404, Size: 159, Words: 6, Lines: 11, Duration: 2ms]
:: Progress: [7/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:01] :: Error
:: Progress: [7/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:01] :: Error
api/auth/logout [Status: 404, Size: 154, Words: 6, Lines: 11, Duration: 2ms]
:: Progress: [8/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:01] :: Error

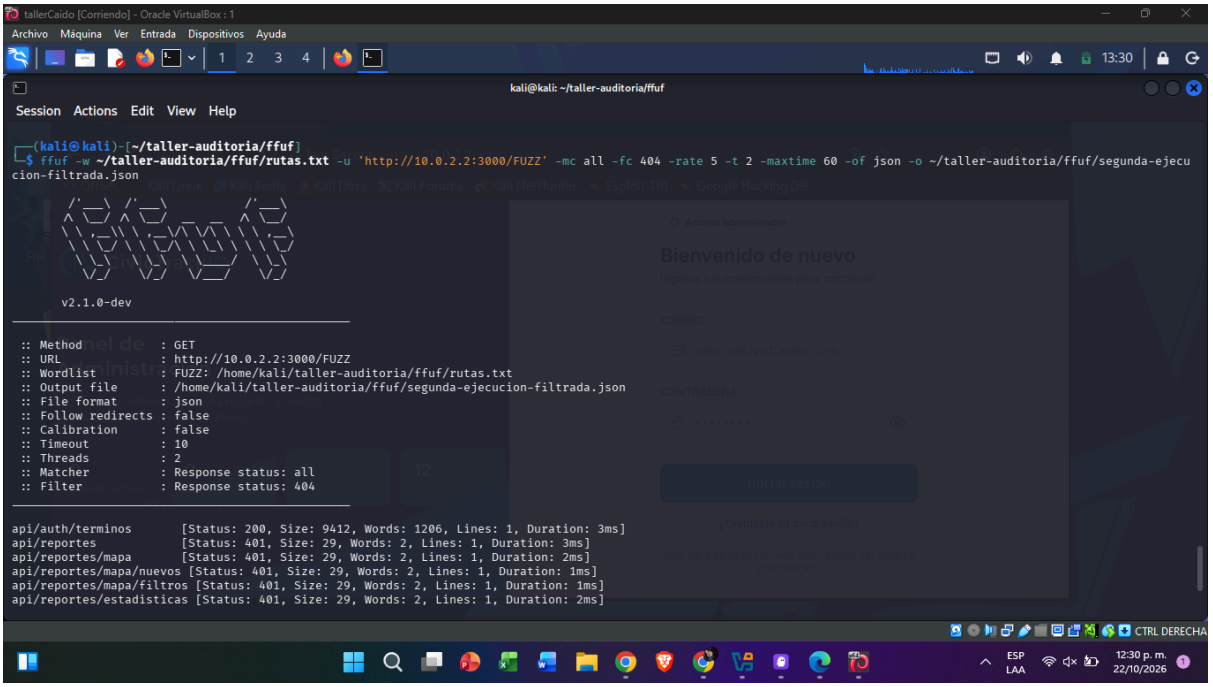

tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
13:24
kali@kali: ~/taller-auditoria/ffuf
Session Actions Edit View Help
:: Progress: [8/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:01] :: Error
:: Progress: [8/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:01] :: Error
api/auth/username [Status: 404, Size: 156, Words: 6, Lines: 11, Duratio
n: 2ms]
:: Progress: [9/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:01] :: Error
:: Progress: [9/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:01] :: Error
api/auth/fcm-token [Status: 404, Size: 157, Words: 6, Lines: 11, Duratio
n: 3ms]
:: Progress: [10/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [10/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [10/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
api/auth/forgot-password [Status: 404, Size: 163, Words: 6, Lines: 11, Durati
on: 2ms]
:: Progress: [11/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [11/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [12/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
api/auth/terminos [Status: 200, Size: 9412, Words: 1206, Lines: 1, Dura
tion: 4ms]
:: Progress: [12/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [12/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
api/reportes [Status: 401, Size: 29, Words: 2, Lines: 1, Duration:
5ms]
:: Progress: [13/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [13/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [13/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
api/reportes/mapa [Status: 401, Size: 29, Words: 2, Lines: 1, Duration:
3ms]
:: Progress: [14/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [14/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
api/reportes/mapa/nuevos [Status: 401, Size: 29, Words: 2, Lines: 1, Duration
: 1ms]
:: Progress: [15/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [15/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
:: Progress: [15/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
CTRL DERECHA
ESP
LAA
12:24 p. m.
22/10/2026

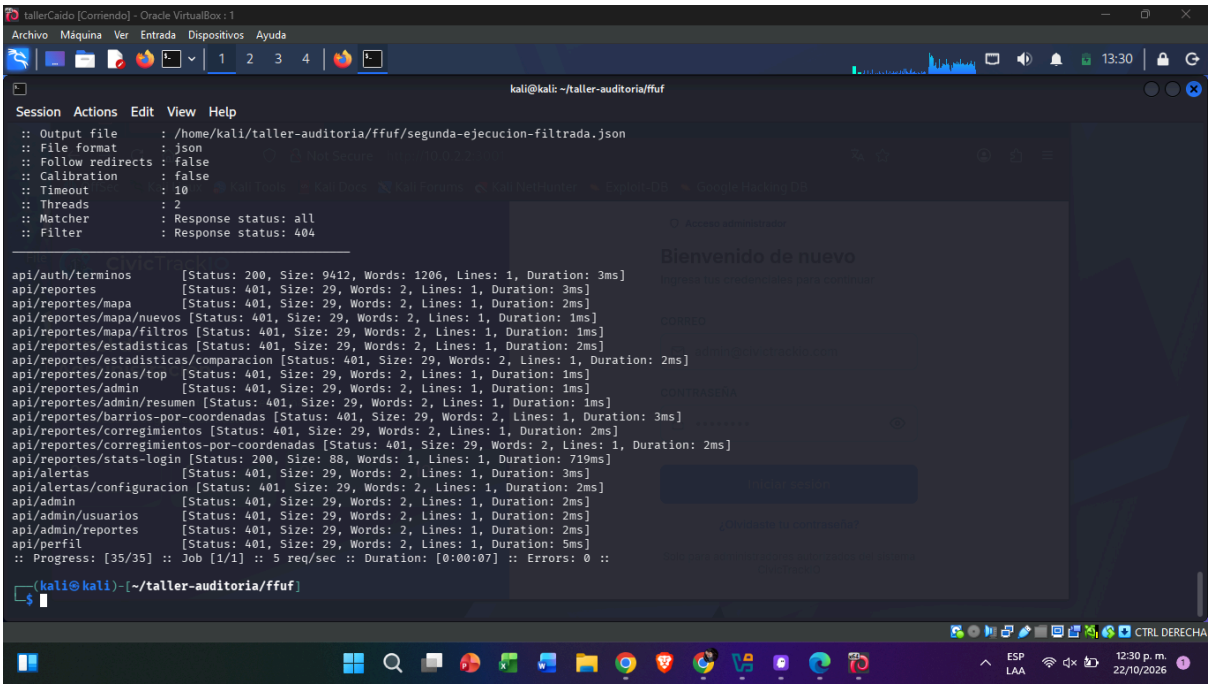

tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
13:25
kali@kali: ~/taller-auditoria/ffuf
Session Actions Edit View Help
:: Progress: [13/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [13/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
api/reportes/mapa [Status: 401, Size: 29, Words: 2, Lines: 1, Duration:
3ms]
:: Progress: [14/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [14/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
api/reportes/mapa/nuevos [Status: 401, Size: 29, Words: 2, Lines: 1, Duration
: 1ms]
:: Progress: [15/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:02] :: Erro
:: Progress: [15/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
:: Progress: [15/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
api/reportes/mapa/filtros [Status: 401, Size: 29, Words: 2, Lines: 1, Duratio
n: 6ms]
:: Progress: [16/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
:: Progress: [16/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
api/reportes/estadisticas [Status: 401, Size: 29, Words: 2, Lines: 1, Duratio
n: 2ms]
:: Progress: [17/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
:: Progress: [17/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
:: Progress: [17/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
api/reportes/estadisticas/comparacion [Status: 401, Size: 29, Words: 2, Lines
: 1, Duration: 1ms]
:: Progress: [18/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
:: Progress: [18/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
:: Progress: [19/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
api/reportes/zonas/top [Status: 401, Size: 29, Words: 2, Lines: 1, Duration:
2ms]
:: Progress: [19/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
:: Progress: [19/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
api/reportes/admin [Status: 401, Size: 29, Words: 2, Lines: 1, Duration:
1ms]
:: Progress: [20/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:03] :: Erro
:: Progress: [20/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:04] :: Erro
:: Progress: [20/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:04] :: Erro
CTRL DERECHA
ESP
LAA
12:25 p. m.
22/10/2026





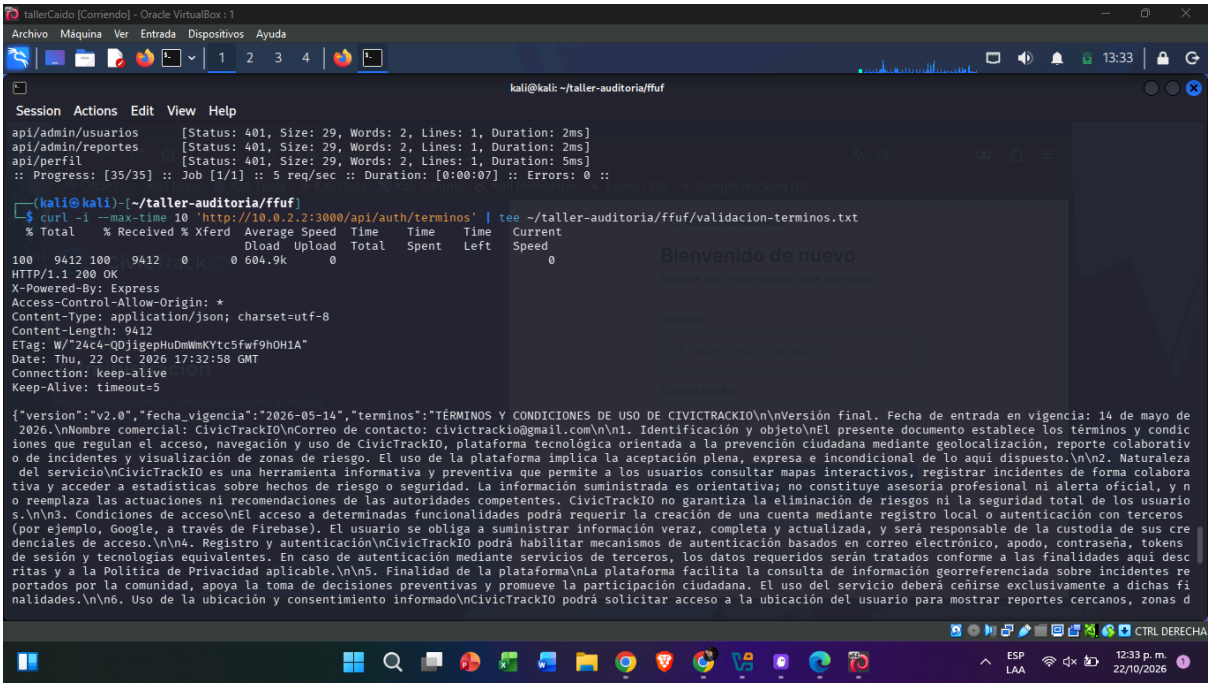
Repetimos con un filtro de códigos.

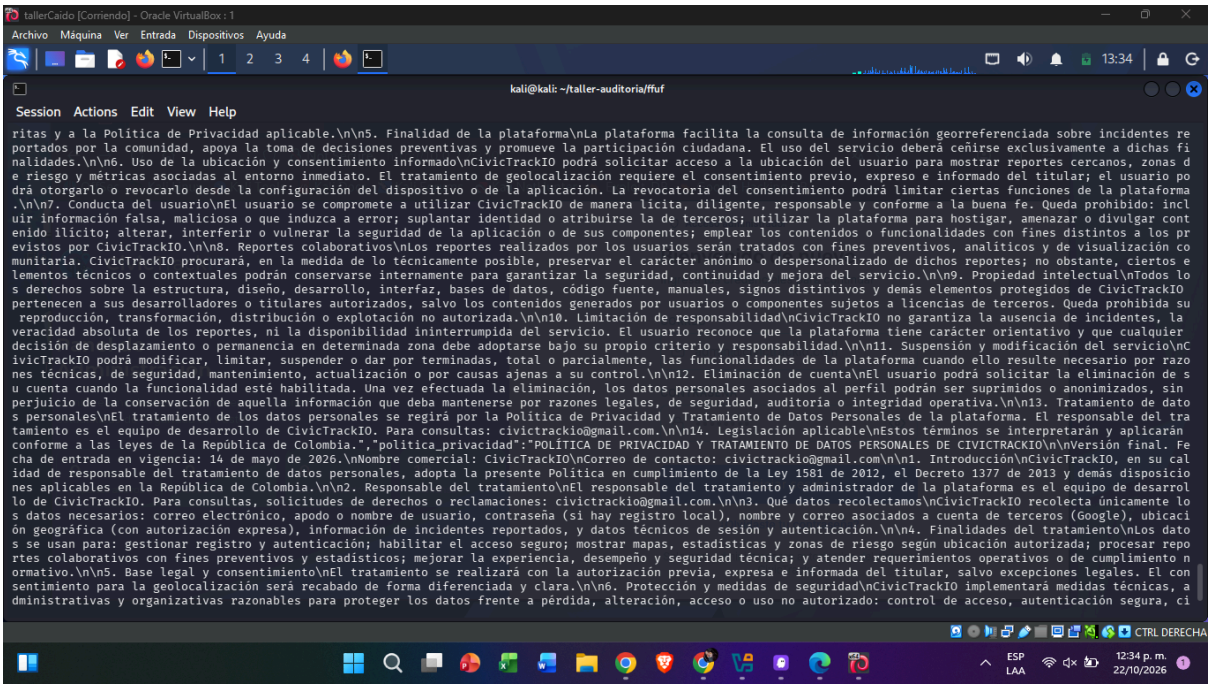


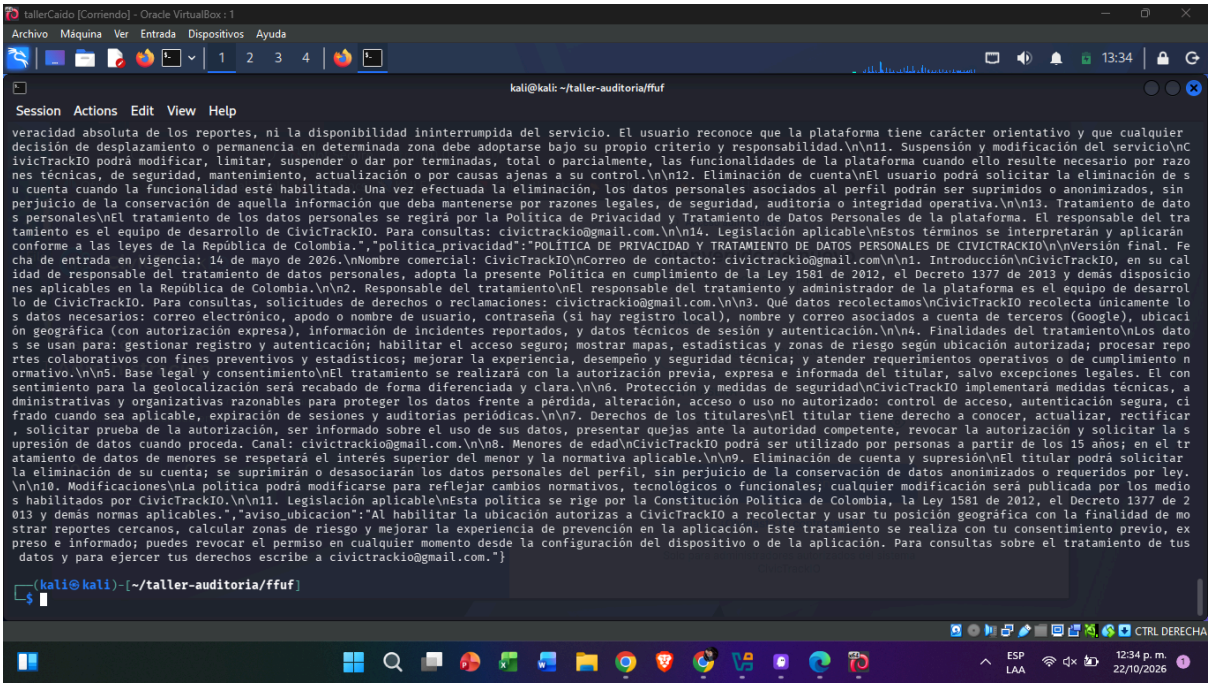


Y confirmamos manualmente las dos respuestas 200.

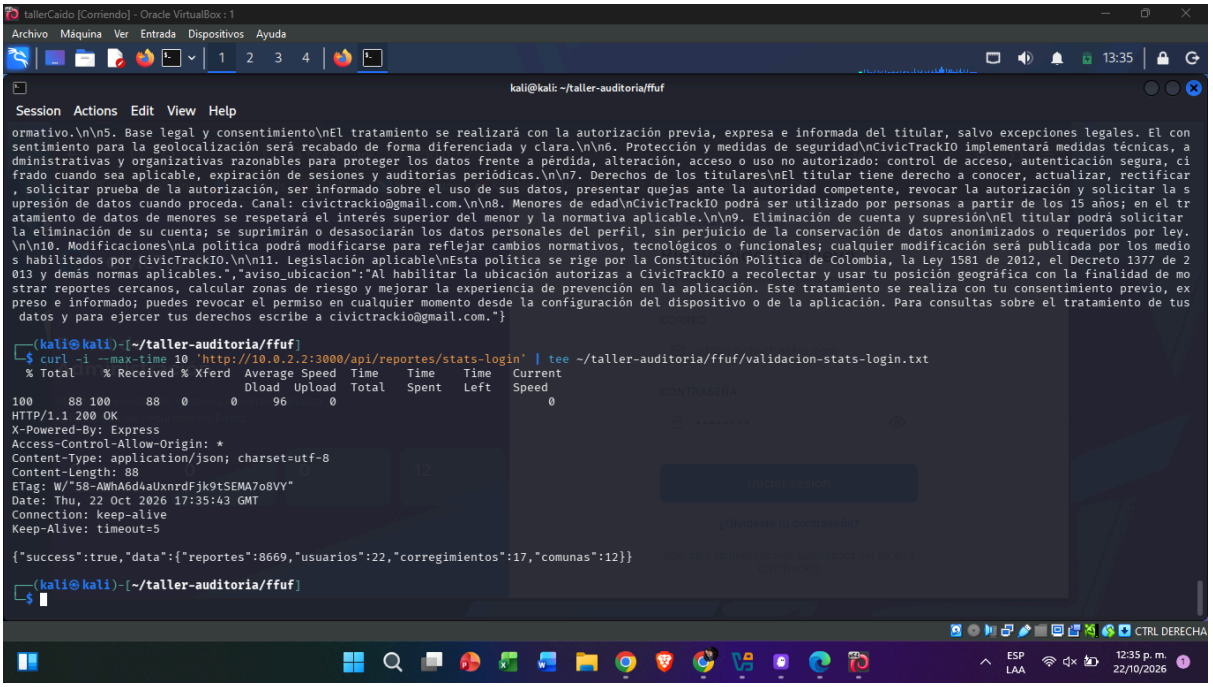
Primero con Términos, revisa si contiene únicamente términos públicos o si incluye información que no debería exponerse.


tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
13:33
kali@kali: ~/taller-auditoria/ffuf
Session Actions Edit View Help
api/admin/usuarios [Status: 401, Size: 29, Words: 2, Lines: 1, Duration: 2ms]
api/admin/reportes [Status: 401, Size: 29, Words: 2, Lines: 1, Duration: 2ms]
api/perfil [Status: 401, Size: 29, Words: 2, Lines: 1, Duration: 5ms]
:: Progress: [35/35] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:07] :: Errors: 0 ::
(kali㉿kali)-[~/taller-auditoria/ffuf]
$ curl -i --max-time 10 'http://10.0.2.2:3000/api/auth/terminos' | tee ~/taller-auditoria/ffuf/validacion-terminos.txt
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 9412 100 9412 0 0 604.9k 0 0
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 9412
ETag: W/"24c4-QDjigepHuDmWmKYtc5fwf9hOH1A"
Date: Thu, 22 Oct 2026 17:32:58 GMT
Connection: keep-alive
Keep-Alive: timeout=5
{"version":"v2.0","fecha_vigencia":"2026-05-14","terminos":"TÉRMINOS Y CONDICIONES DE USO DE CIVICTRACKIO\n\nVersión final. Fecha de entrada en vigencia: 14 de mayo de 2026.\nNombre comercial: CivicTrackIO\nCorreo de contacto: civictrackio@gmail.com\n\n1. Identificación y objeto\nEl presente documento establece los términos y condiciones que regulan el acceso, navegación y uso de CivicTrackIO, plataforma tecnológica orientada a la prevención ciudadana mediante geolocalización, reporte colaborativo de incidentes y visualización de zonas de riesgo. El uso de la plataforma implica la aceptación plena, expresa e incondicional de lo aquí dispuesto.\n\n2. Naturaleza del servicio\nCivicTrackIO es una herramienta informativa y preventiva que permite a los usuarios consultar mapas interactivos, registrar incidentes de forma colaborativa y acceder a estadísticas sobre hechos de riesgo o seguridad. La información suministrada es orientativa; no constituye asesoría profesional ni alerta oficial, y no reemplaza las actuaciones ni recomendaciones de las autoridades competentes. CivicTrackIO no garantiza la eliminación de riesgos ni la seguridad total de los usuarios.\n\n3. Condiciones de acceso\nEl acceso a determinadas funcionalidades podrá requerir la creación de una cuenta mediante registro local o autenticación con terceros (por ejemplo, Google, a través de Firebase). El usuario se obliga a suministrar información veraz, completa y actualizada, y será responsable de la custodia de sus credenciales de acceso.\n\n4. Registro y autenticación\nCivicTrackIO podrá habilitar mecanismos de autenticación basados en correo electrónico, apodo, contraseña, tokens de sesión y tecnologías equivalentes. En caso de autenticación mediante servicios de terceros, los datos requeridos serán tratados conforme a las finalidades aquí descritas y a la Política de Privacidad aplicable.\n\n5. Finalidad de la plataforma\nLa plataforma facilita la consulta de información georreferenciada sobre incidentes reportados por la comunidad, apoya la toma de decisiones preventivas y promueve la participación ciudadana. El uso del servicio deberá ceñirse exclusivamente a dichas finalidades.\n\n6. Uso de la ubicación y consentimiento informado\nCivicTrackIO podrá solicitar acceso a la ubicación del usuario para mostrar reportes cercanos, zonas d
CTRL DERECHA
ESP LAA
12:33 p. m. 22/10/2026

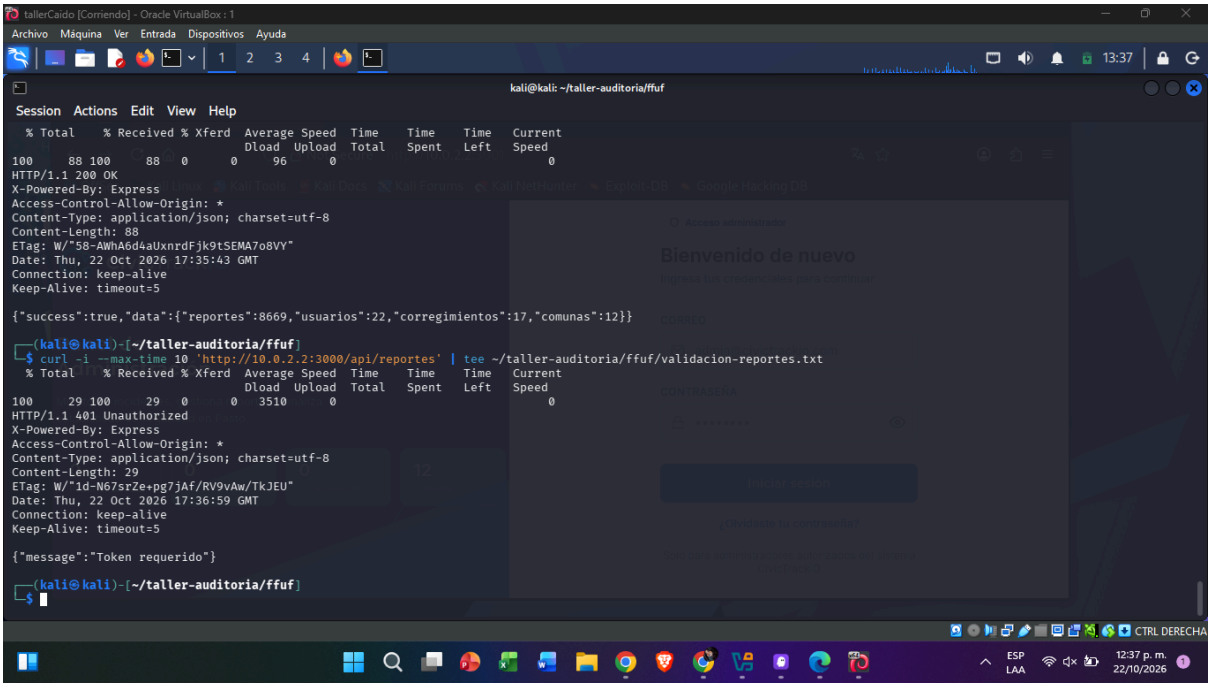

tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
13:34
kali@kali: ~/taller-auditoria/ffuf
Session Actions Edit View Help
ritas y a la Política de Privacidad aplicable.\n\n5. Finalidad de la plataforma\nLa plataforma facilita la consulta de información georreferenciada sobre incidentes reportados por la comunidad, apoya la toma de decisiones preventivas y promueve la participación ciudadana. El uso del servicio deberá ceñirse exclusivamente a dichas finalidades.\n\n6. Uso de la ubicación y consentimiento informado\nCivicTrackIO podrá solicitar acceso a la ubicación del usuario para mostrar reportes cercanos, zonas de riesgo y métricas asociadas al entorno inmediato. El tratamiento de geolocalización requiere el consentimiento previo, expreso e informado del titular; el usuario podrá otorgarlo o revocarlo desde la configuración del dispositivo o de la aplicación. La revocatoria del consentimiento podrá limitar ciertas funciones de la plataforma.\n\n7. Conducta del usuario\nEl usuario se compromete a utilizar CivicTrackIO de manera lícita, diligente, responsable y conforme a la buena fe. Queda prohibido: incluir información falsa, maliciosa o que induzca a error; suplantar identidad o atribuirse la de terceros; utilizar la plataforma para hostigar, amenazar o divulgar contenido ilícito; alterar, interferir o vulnerar la seguridad de la aplicación o de sus componentes; emplear los contenidos o funcionalidades con fines distintos a los previstos por CivicTrackIO.\n\n8. Reportes colaborativos\nLos reportes realizados por los usuarios serán tratados con fines preventivos, analíticos y de visualización comunitaria. CivicTrackIO procurará, en la medida de lo técnicamente posible, preservar el carácter anónimo o despersonalizado de dichos reportes; no obstante, ciertos elementos técnicos o contextuales podrán conservarse internamente para garantizar la seguridad, continuidad y mejora del servicio.\n\n9. Propiedad intelectual\nTodos los derechos sobre la estructura, diseño, desarrollo, interfaz, bases de datos, código fuente, manuales, signos distintivos y demás elementos protegidos de CivicTrackIO pertenecen a sus desarrolladores o titulares autorizados, salvo los contenidos generados por usuarios o componentes sujetos a licencias de terceros. Queda prohibida su reproducción, transformación, distribución o explotación no autorizada.\n\n10. Limitación de responsabilidad\nCivicTrackIO no garantiza la ausencia de incidentes, la veracidad absoluta de los reportes, ni la disponibilidad ininterrumpida del servicio. El usuario reconoce que la plataforma tiene carácter orientativo y que cualquier decisión de desplazamiento o permanencia en determinada zona debe adoptarse bajo su propio criterio y responsabilidad.\n\n11. Suspensión y modificación del servicio\nCivicTrackIO podrá modificar, limitar, suspender o dar por terminadas, total o parcialmente, las funcionalidades de la plataforma cuando ello resulte necesario por razones técnicas, de seguridad, mantenimiento, actualización o por causas ajenas a su control.\n\n12. Eliminación de cuenta\nEl usuario podrá solicitar la eliminación de su cuenta cuando la funcionalidad esté habilitada. Una vez efectuada la eliminación, los datos personales asociados al perfil podrán ser suprimidos o anonimizados, sin perjuicio de la conservación de aquella información que deba mantenerse por razones legales, de seguridad, auditoría o integridad operativa.\n\n13. Tratamiento de datos personales\nEl tratamiento de los datos personales se regirá por la Política de Privacidad y Tratamiento de Datos Personales de la plataforma. El responsable del tratamiento es el equipo de desarrollo de CivicTrackIO. Para consultas: civictrackio@gmail.com.\n\n14. Legislación aplicable\nEstos términos se interpretarán y aplicarán conforme a las leyes de la República de Colombia.","politica_privacidad":"POLÍTICA DE PRIVACIDAD Y TRATAMIENTO DE DATOS PERSONALES DE CIVICTRACKIO\n\nVersión final. Fecha de entrada en vigencia: 14 de mayo de 2026.\nNombre comercial: CivicTrackIO\nCorreo de contacto: civictrackio@gmail.com\n\n1. Introducción\nCivicTrackIO, en su calidad de responsable del tratamiento de datos personales, adopta la presente Política en cumplimiento de la Ley 1581 de 2012, el Decreto 1377 de 2013 y demás disposiciones aplicables en la República de Colombia.\n\n2. Responsable del tratamiento\nEl responsable del tratamiento y administrador de la plataforma es el equipo de desarrollo de CivicTrackIO. Para consultas, solicitudes de derechos o reclamaciones: civictrackio@gmail.com.\n\n3. Qué datos recolectamos\nCivicTrackIO recolecta únicamente los datos necesarios: correo electrónico, apodo o nombre de usuario, contraseña (si hay registro local), nombre y correo asociados a cuenta de terceros (Google), ubicación geográfica (con autorización expresa), información de incidentes reportados, y datos técnicos de sesión y autenticación.\n\n4. Finalidades del tratamiento\nLos datos se usan para: gestionar registro y autenticación; habilitar el acceso seguro; mostrar mapas, estadísticas y zonas de riesgo según ubicación autorizada; procesar reportes colaborativos con fines preventivos y estadísticos; mejorar la experiencia, desempeño y seguridad técnica; y atender requerimientos operativos o de cumplimiento normativo.\n\n5. Base legal y consentimiento\nEl tratamiento se realizará con la autorización previa, expresa e informada del titular, salvo excepciones legales. El consentimiento para la geolocalización será recabado de forma diferenciada y clara.\n\n6. Protección y medidas de seguridad\nCivicTrackIO implementará medidas técnicas, administrativas y organizativas razonables para proteger los datos frente a pérdida, alteración, acceso o uso no autorizado: control de acceso, autenticación segura, ci
CTRL DERECHA
ESP LAA
12:34 p. m. 22/10/2026



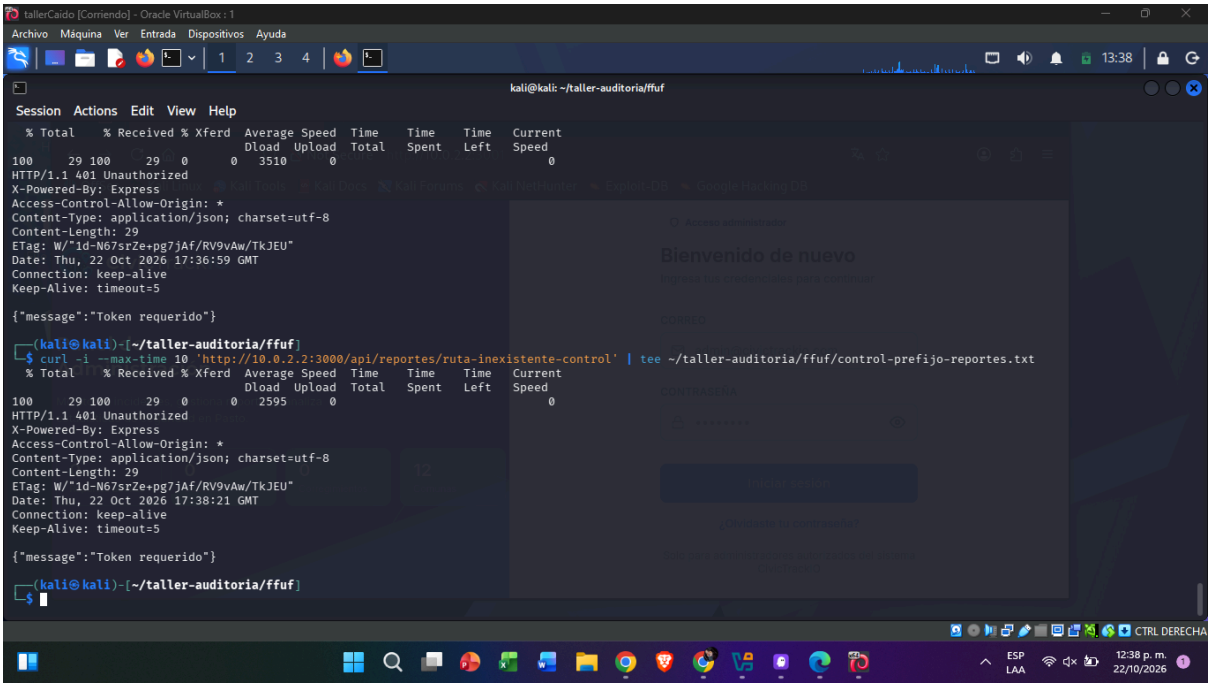
Revisamos también estadísticas de inicio de sesión, aquí necesitamos conocer qué devuelve realmente. El nombre de la ruta y sus 88 bytes no permiten determinar si revela datos sensibles o solo estadísticas destinadas a mostrarse públicamente.



Para seguir, ahora comprobamos una respuesta 401 y su ruta de control.



Ahora hacemos una prueba con una ruta deliberadamente inexistente dentro del mismo prefijo:

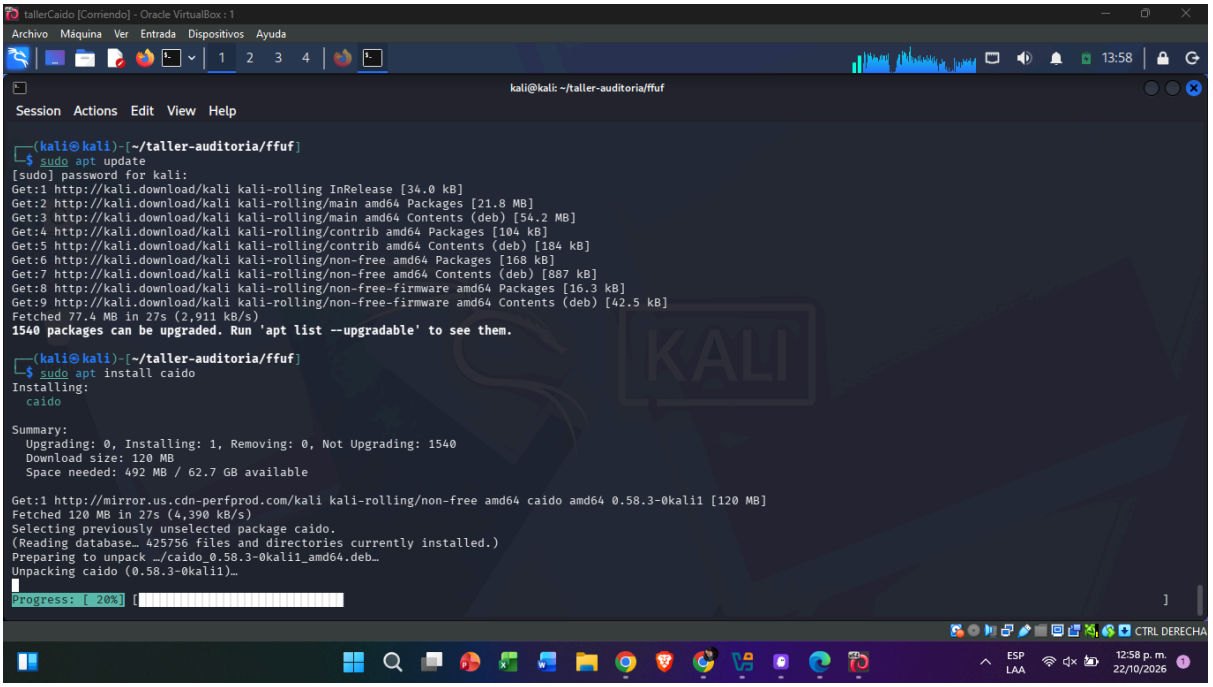


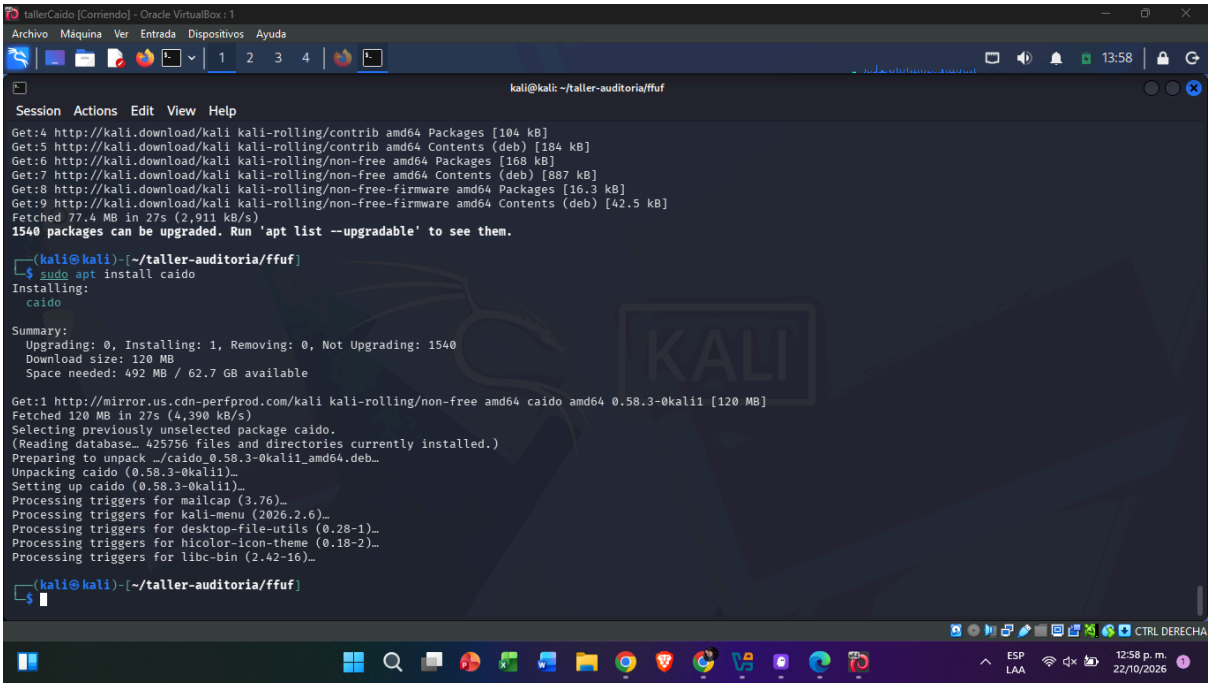
Para finalizar con este comando podemos destacar lo siguiente:

Ruta	Resultado confirmado	Interpretación

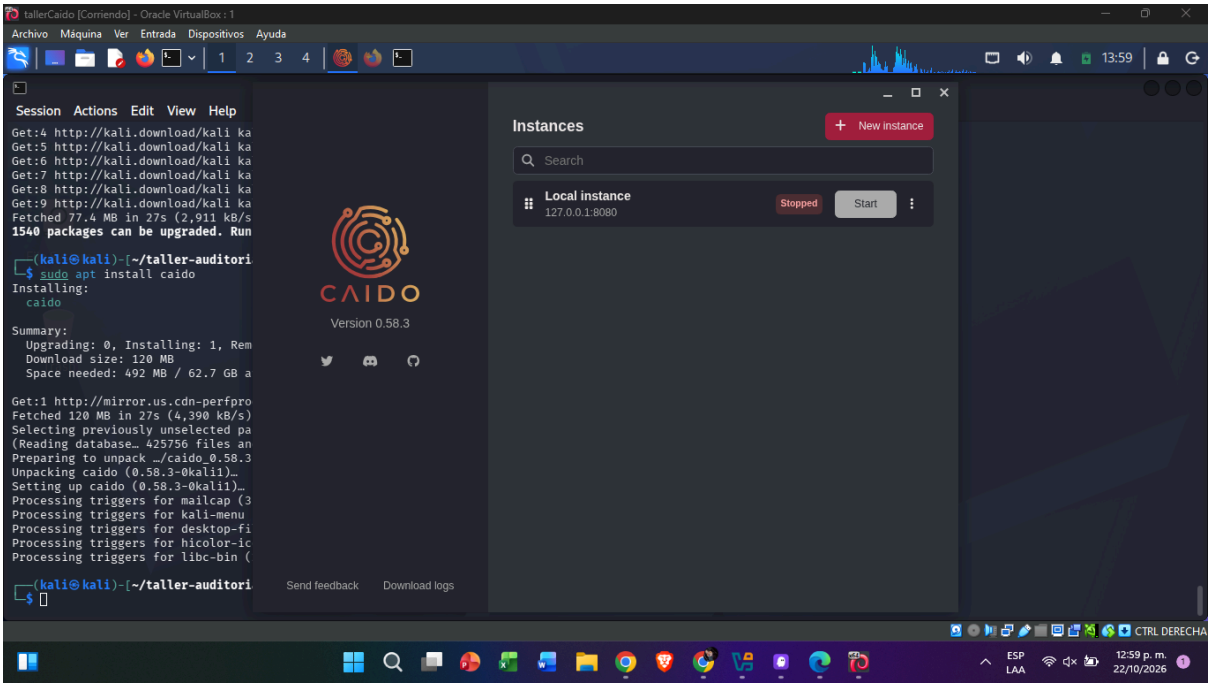
/api/auth/terminos	200, devuelve términos, política y aviso de ubicación	Contenido público; en la respuesta mostrada no se observa exposición de credenciales ni registros personales.
/api/reportes/stats-login	200, devuelve conteos agregados	Expone estadísticas sin autenticación. Según el manejo del proyecto si está previsto mostrarlas públicamente en el inicio de sesión. No constituye automáticamente una vulnerabilidad.
/api/reportes	401, Token requerido	La petición sin credenciales es rechazada. Falta comprobar el endpoint con una sesión válida.
/api/reportes/ruta-inexistente-control	El mismo 401 y mensaje	El rechazo no permite distinguir por sí solo una ruta real de una inexistente dentro de ese prefijo.

Ahora para pasar al proceso de CAIDO, primero instalamos el entorno.

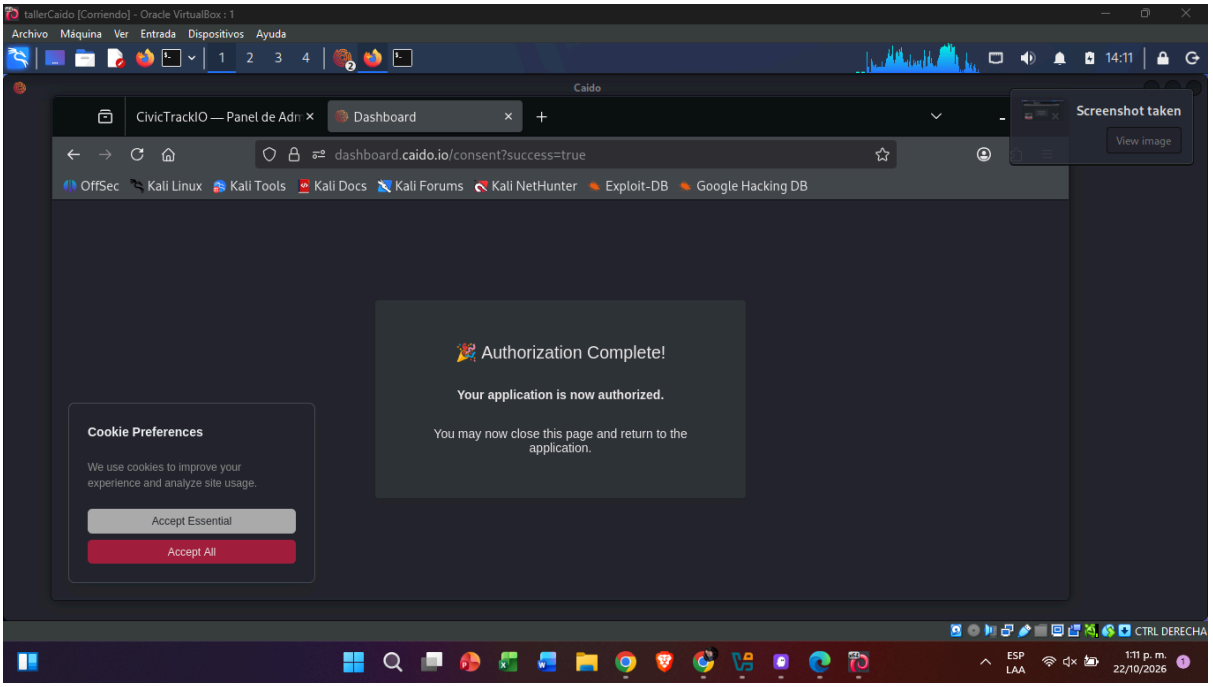




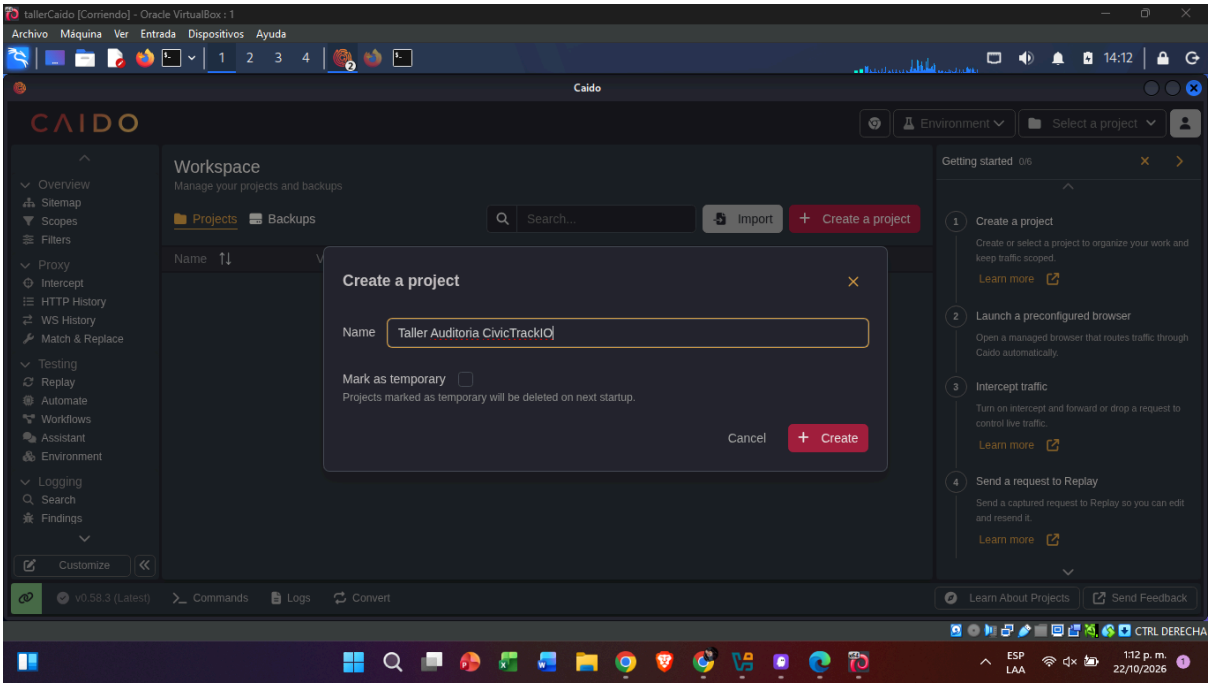
Abrimos CAIDO:



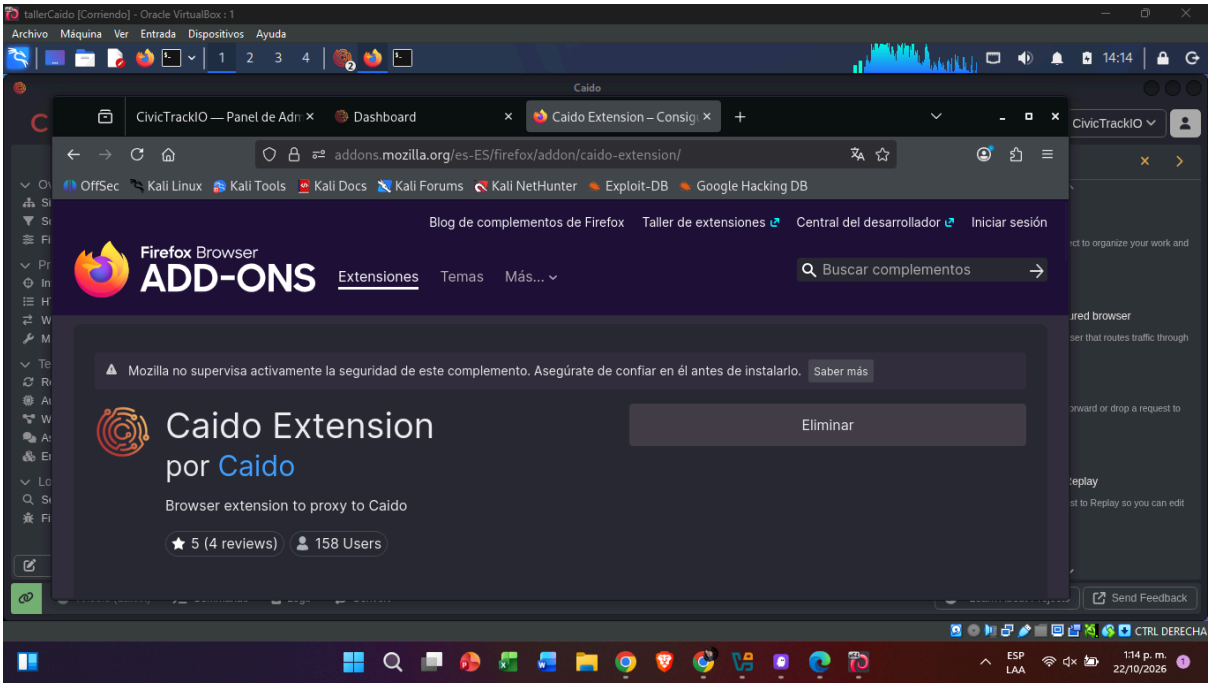
Completamos el registro en CAIDO.



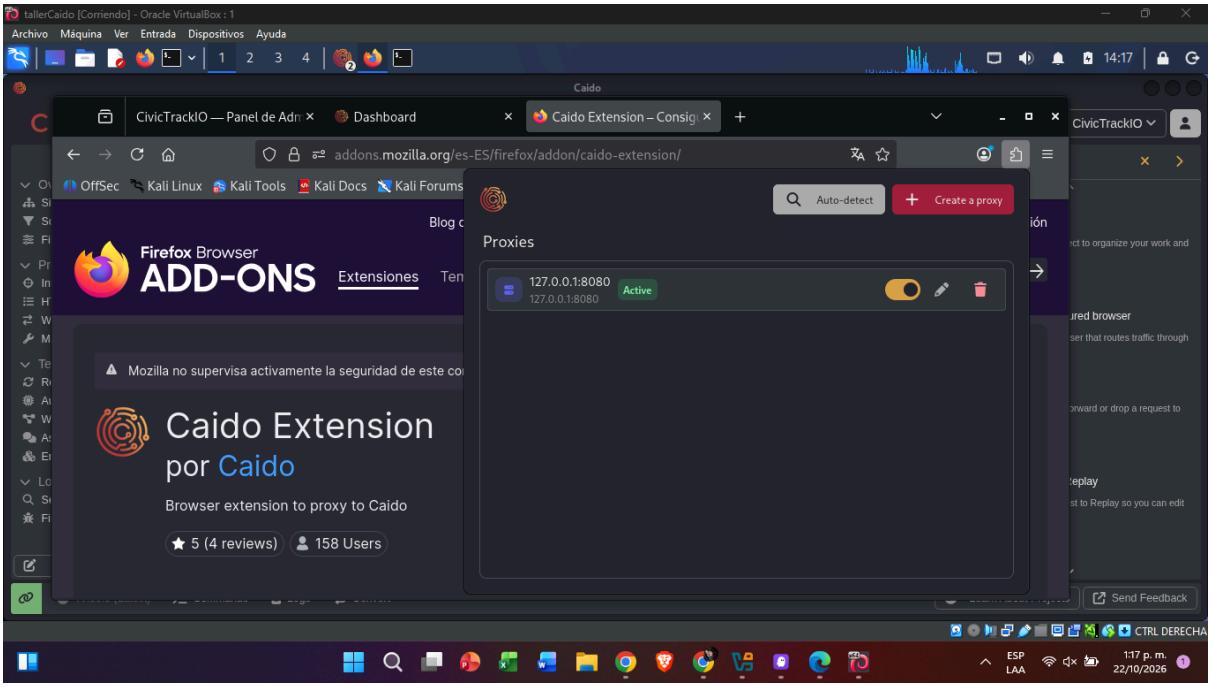
Creamos un nuevo proyecto:



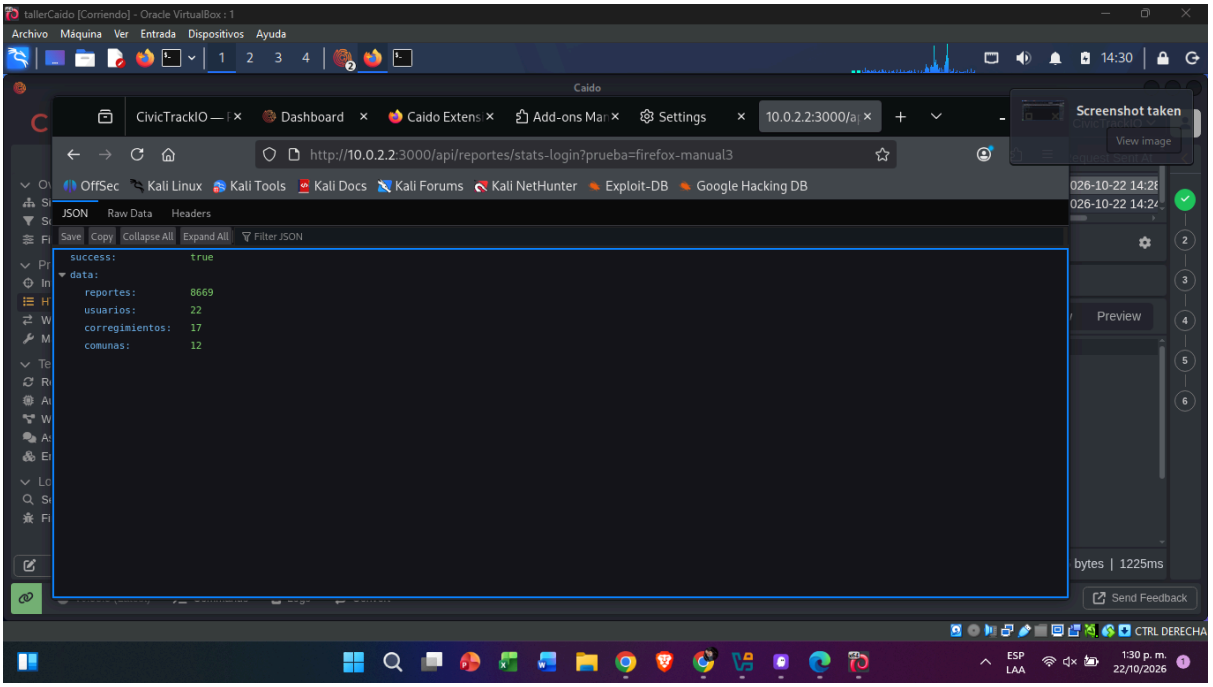
Para el manejo de esta herramienta vamos a usar la extensión oficial de CAIDO:



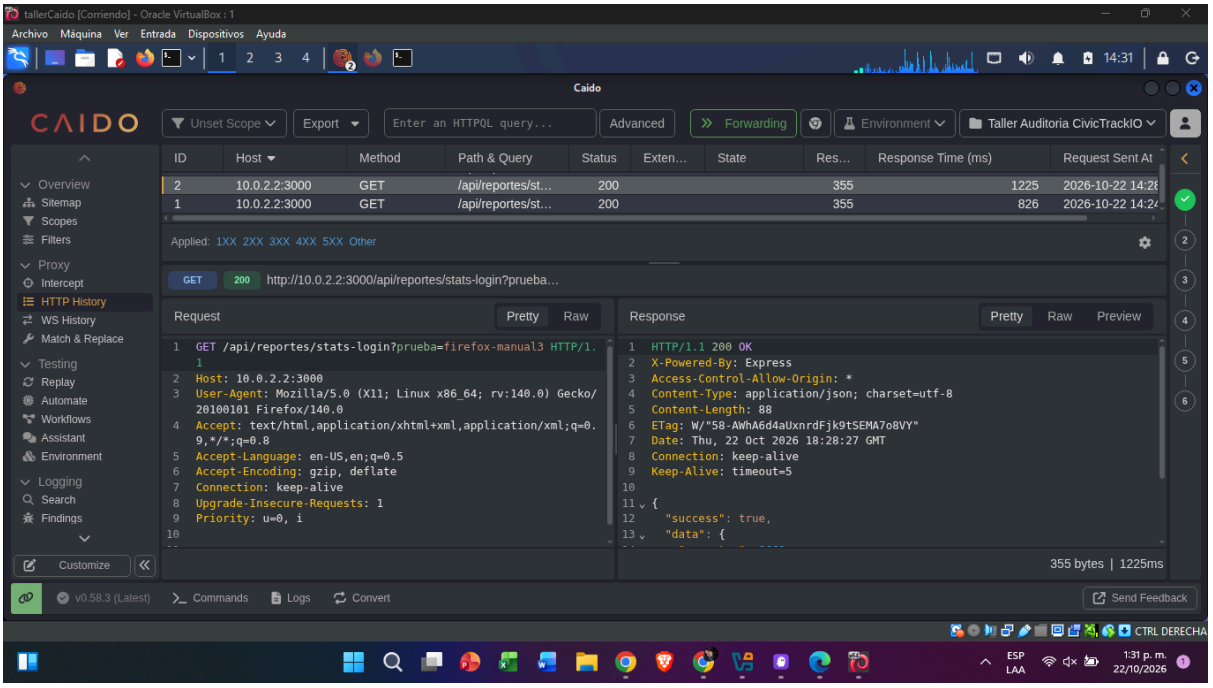
Activamos para que comience a escuchar todo:



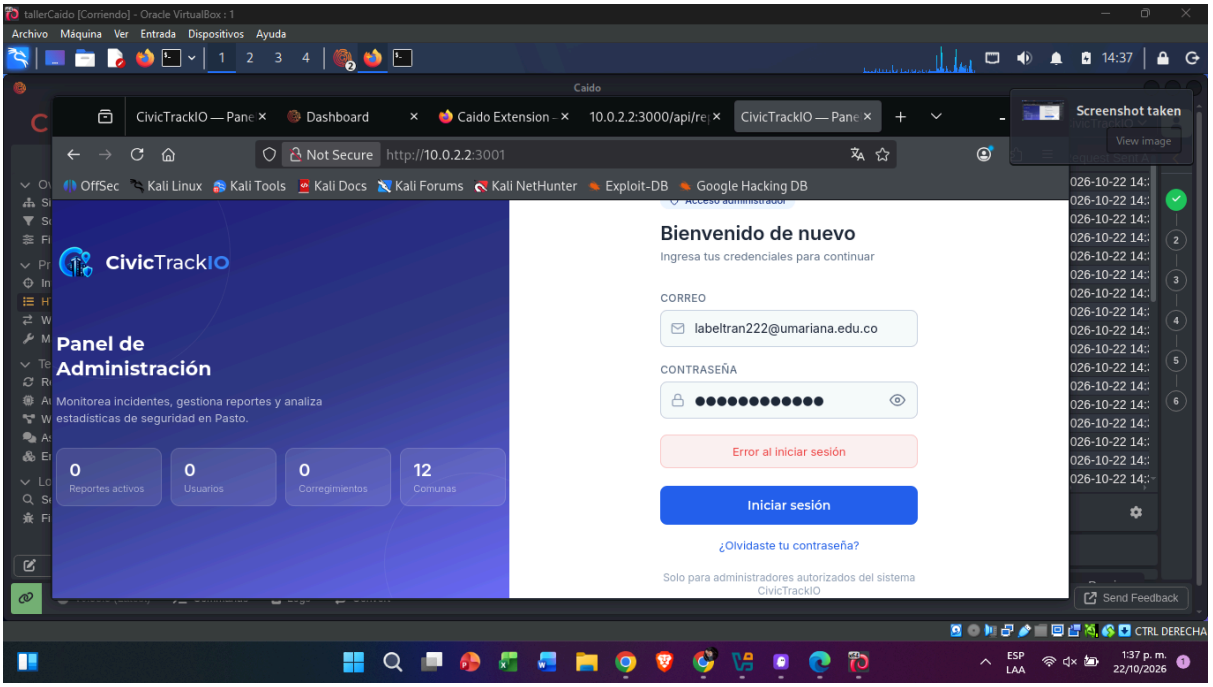
Comprobamos que si este funcionando en firefox y que el tráfico este pasando por CAIDO:

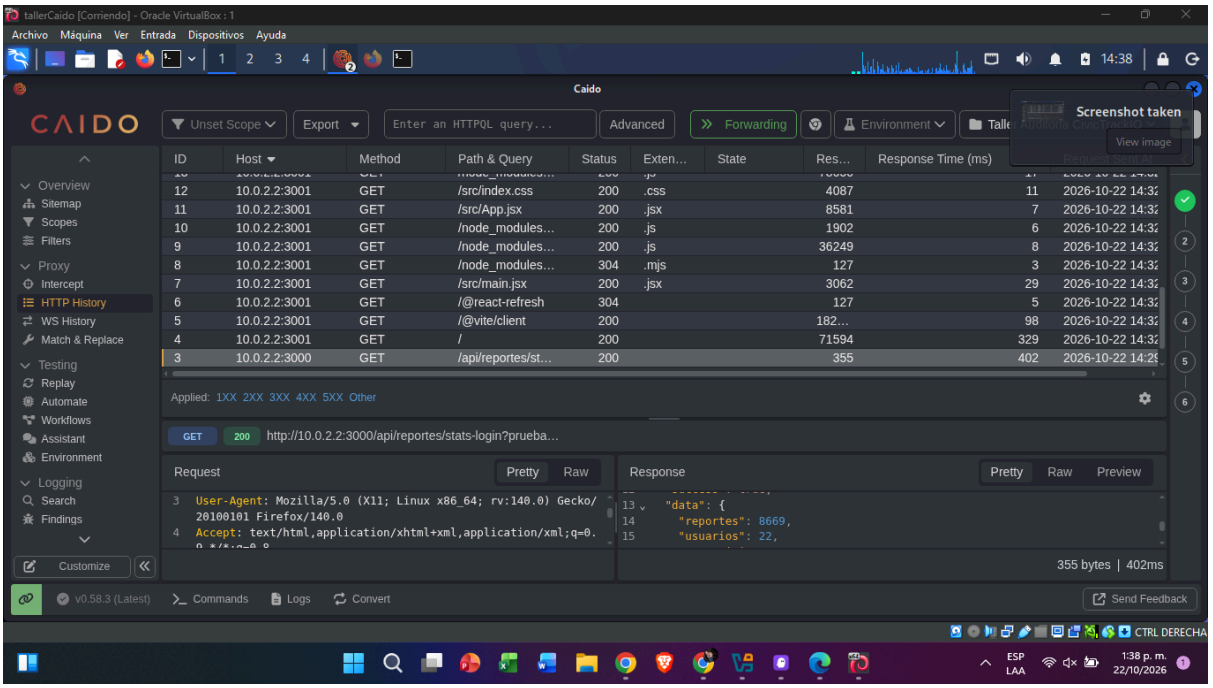


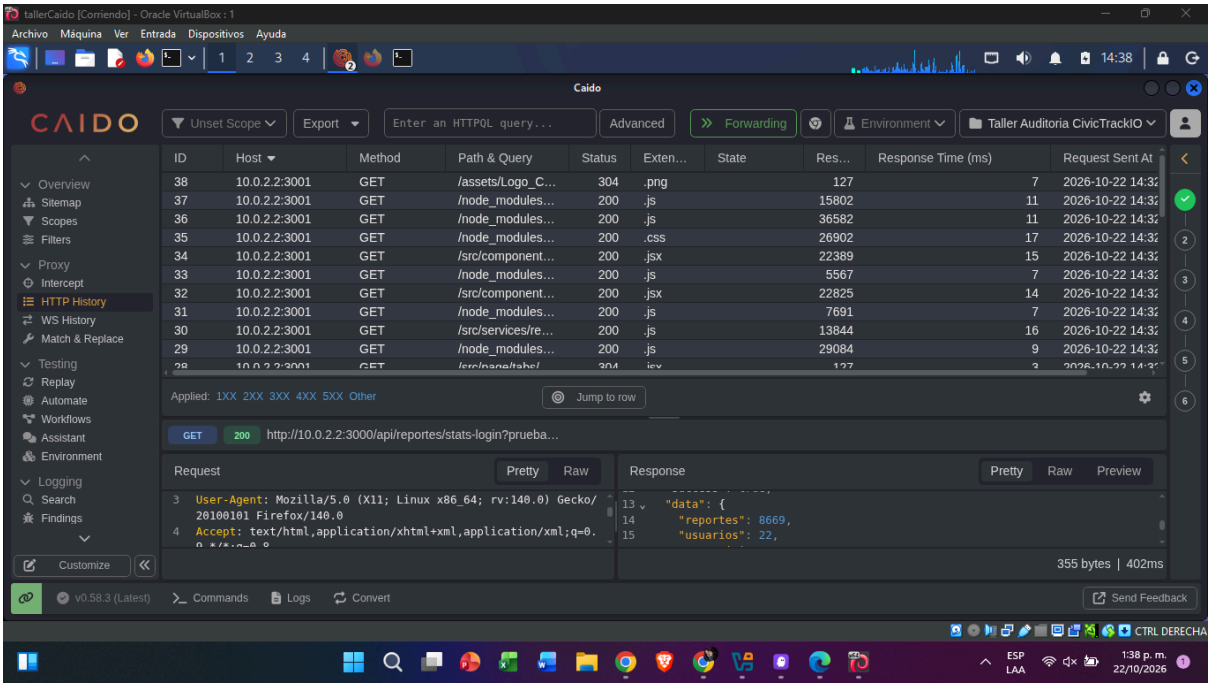
Y comprobamos que esté registrada dentro del sistema de CAIDO:

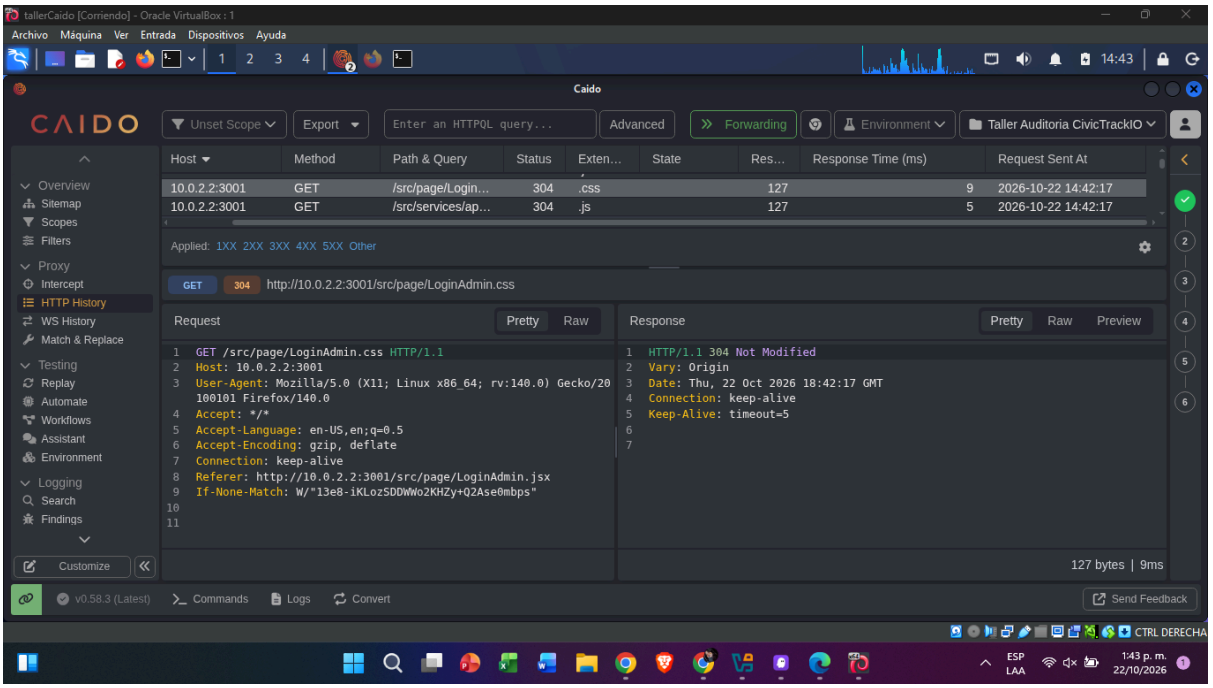


Ahora, intentamos iniciar sesión con un perfil ya registrado y comprobamos el tráfico que pasa por CAIDO.

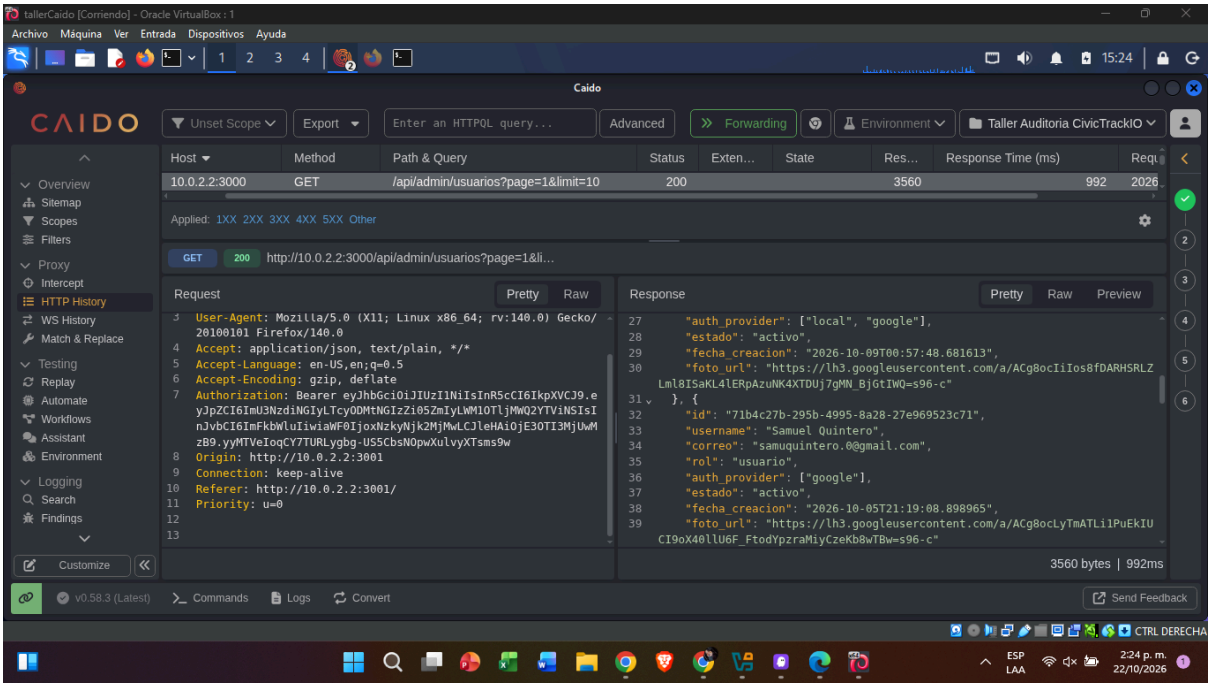

tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
Caido
CivicTrackIO — Pane
Dashboard
Caido Extension
10.0.2.2:3000/api/re
CivicTrackIO — Pane
Not Secure
http://10.0.2.2:3001
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
CivicTrackIO
Panel de Administración
Monitorea incidentes, gestiona reportes y analiza estadisticas de seguridad en Pasto.
0 Reportes activos
0 Usuarios
0 Corregimientos
12 Comunas
Bienvenido de nuevo
Ingresa tus credenciales para continuar
CORREO
labeltran222@umariana.edu.co
CONTRASEÑA
Error al iniciar sesión
Iniciar sesión
¿Olvidaste tu contraseña?
Solo para administradores autorizados del sistema CivicTrackIO
Screenshot taken
View image
Send Feedback
CTRL DERECHA
ESP LAA
1:37 p. m. 22/10/2026


tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
Caido
CAIDO
Unset Scope
Export
Enter an HTTPQL query...
Advanced
Forwarding
Environment
Overview
Sitemap
Scopes
Filters
Proxy
Intercept
HTTP History
WS History
Match & Replace
Testing
Replay
Automate
Workflows
Assistant
Environment
Logging
Search
Findings
Customize
ID Host Method Path & Query Status Exten... State Res... Response Time (ms)
12 10.0.2.2:3001 GET /src/index.css 200 .css 4087 11 2026-10-22 14:32
11 10.0.2.2:3001 GET /src/App.jsx 200 .jsx 8581 7 2026-10-22 14:32
10 10.0.2.2:3001 GET /node_modules... 200 .js 1902 6 2026-10-22 14:32
9 10.0.2.2:3001 GET /node_modules... 200 .js 36249 8 2026-10-22 14:32
8 10.0.2.2:3001 GET /node_modules... 304 .mjs 127 3 2026-10-22 14:32
7 10.0.2.2:3001 GET /src/main.jsx 200 .jsx 3062 29 2026-10-22 14:32
6 10.0.2.2:3001 GET /@react-refresh 304 127 5 2026-10-22 14:32
5 10.0.2.2:3001 GET /@vite/client 200 182... 98 2026-10-22 14:32
4 10.0.2.2:3001 GET / 200 71594 329 2026-10-22 14:32
3 10.0.2.2:3000 GET /api/reportes/st... 200 355 402 2026-10-22 14:29
Applied: 1XX 2XX 3XX 4XX 5XX Other
GET 200 http://10.0.2.2:3000/api/reportes/stats-login?prueba...
Request Pretty Raw
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.
Response Pretty Raw Preview
"data": {
"reportes": 8669,
"usuarios": 22,
355 bytes | 402ms
v0.58.3 (Latest) Commands Logs Convert
Send Feedback
Screenshot taken
View image
CTRL DERECHA
ESP LAA
1:38 p. m. 22/10/2026

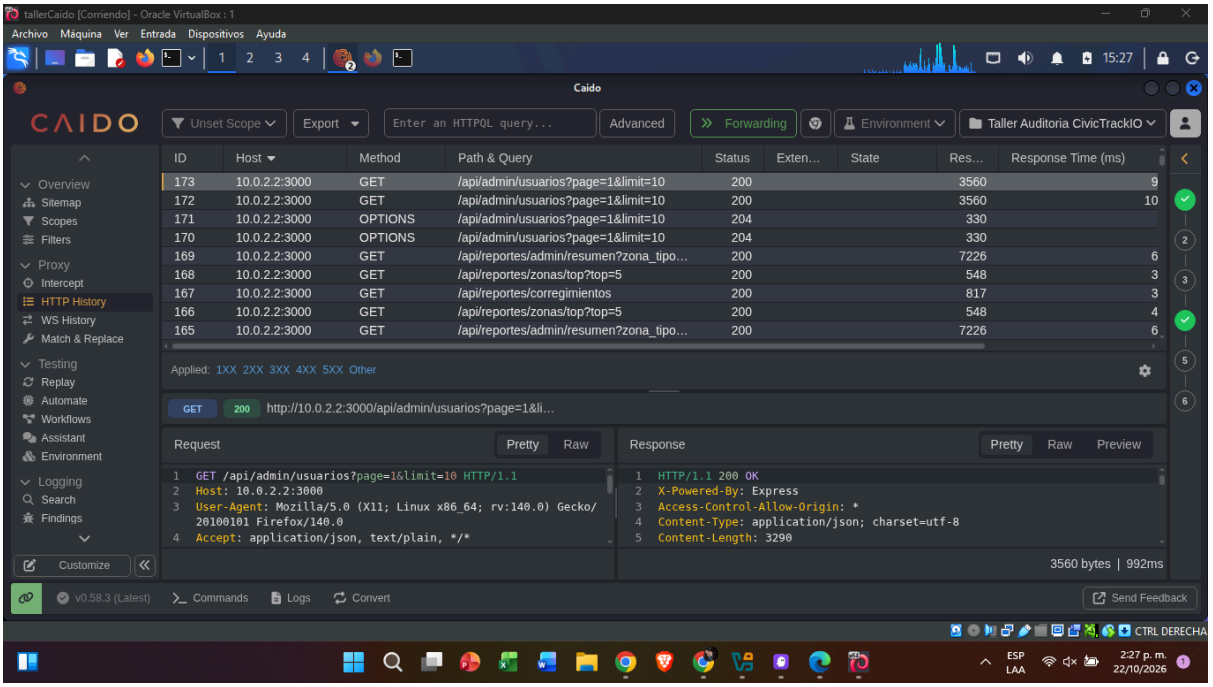




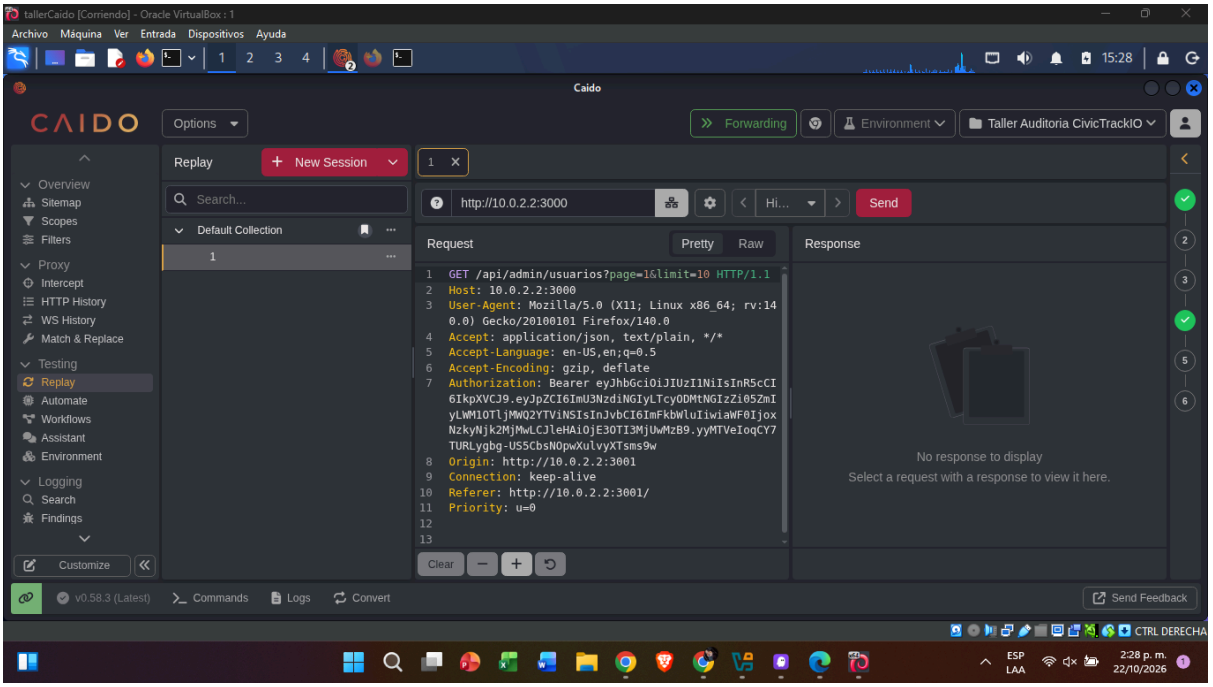
Ahora pasamos a completar pruebas con secciones donde solo el administrador puede acceder y tener información y como esta se ve dentro de lo que es CAIDO



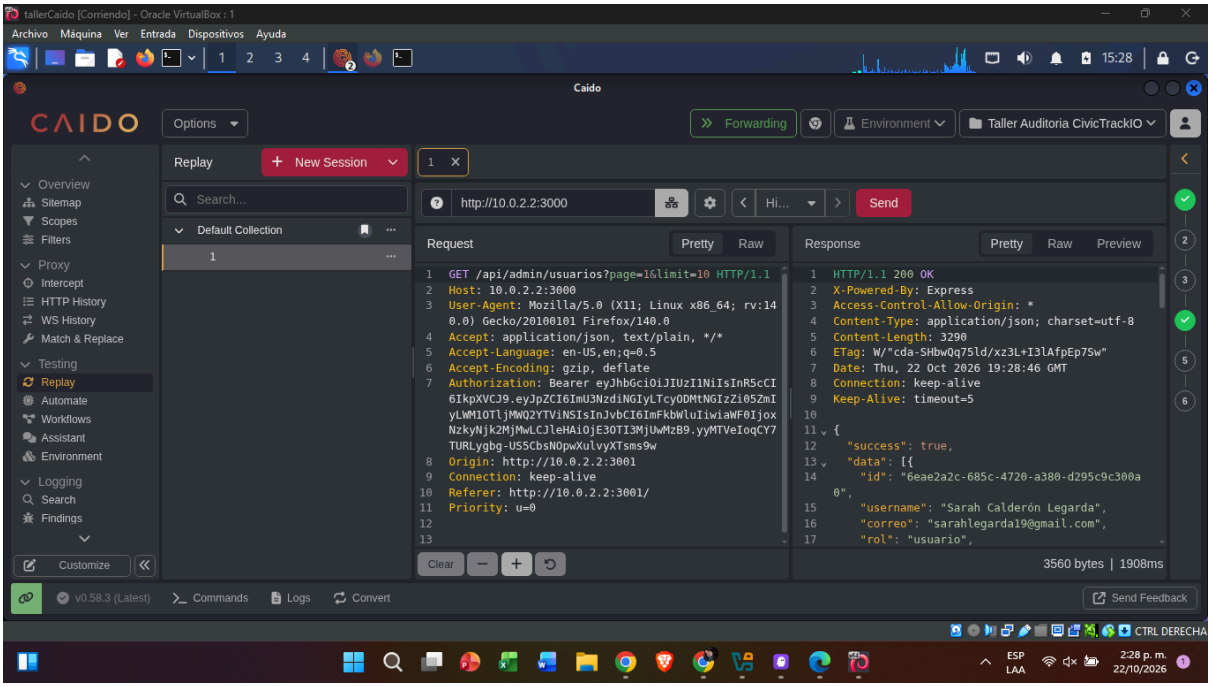
Hacemos el envío de una petición que nos entregue información y la mandamos al Replay

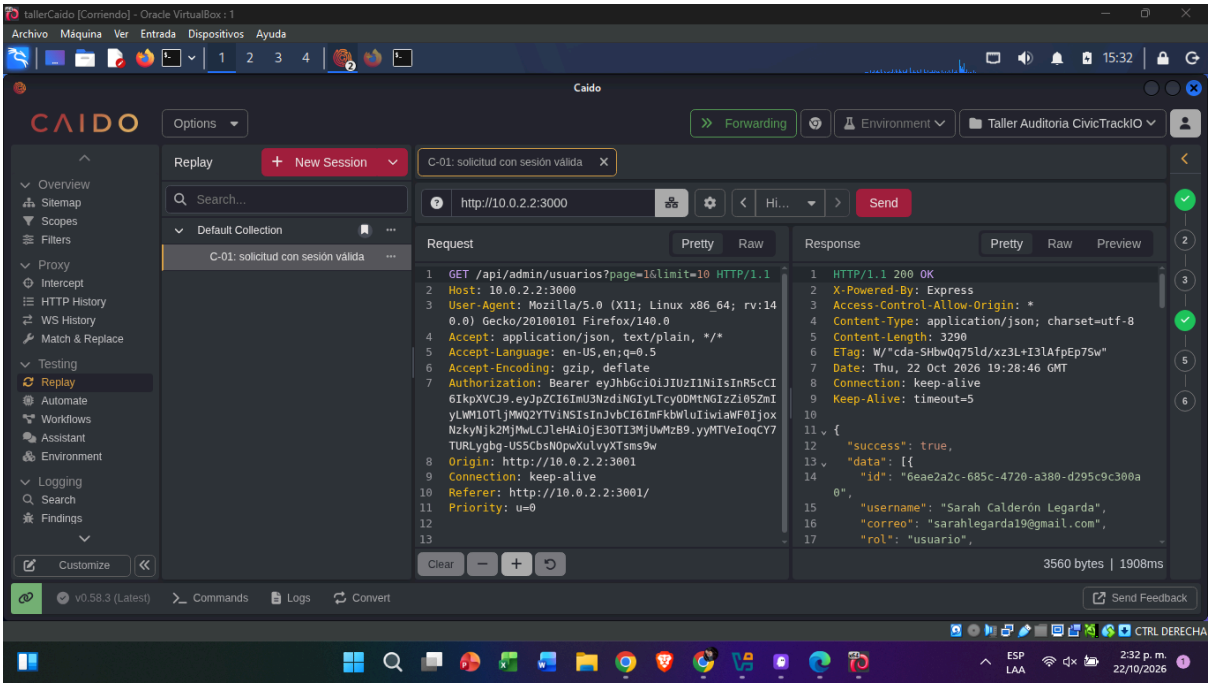


Ahora, vamos a Replay y envíamos esa solicitud.

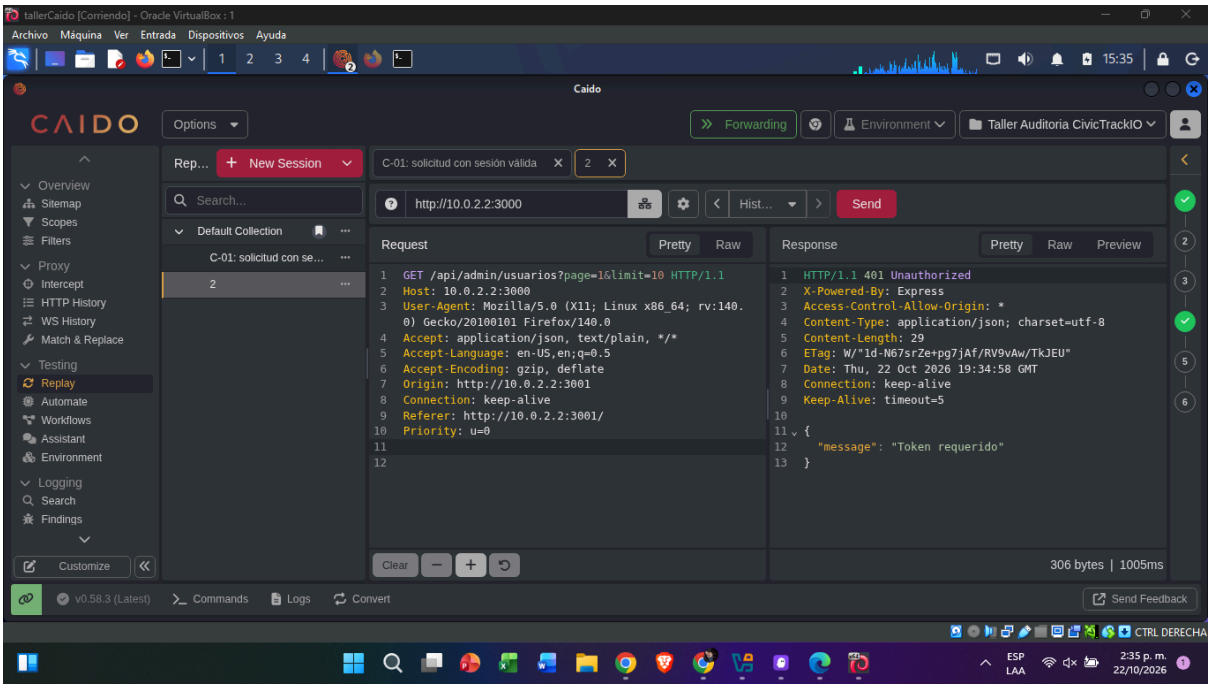


Y esta es la respuesta que se da cuando le damos click en send.

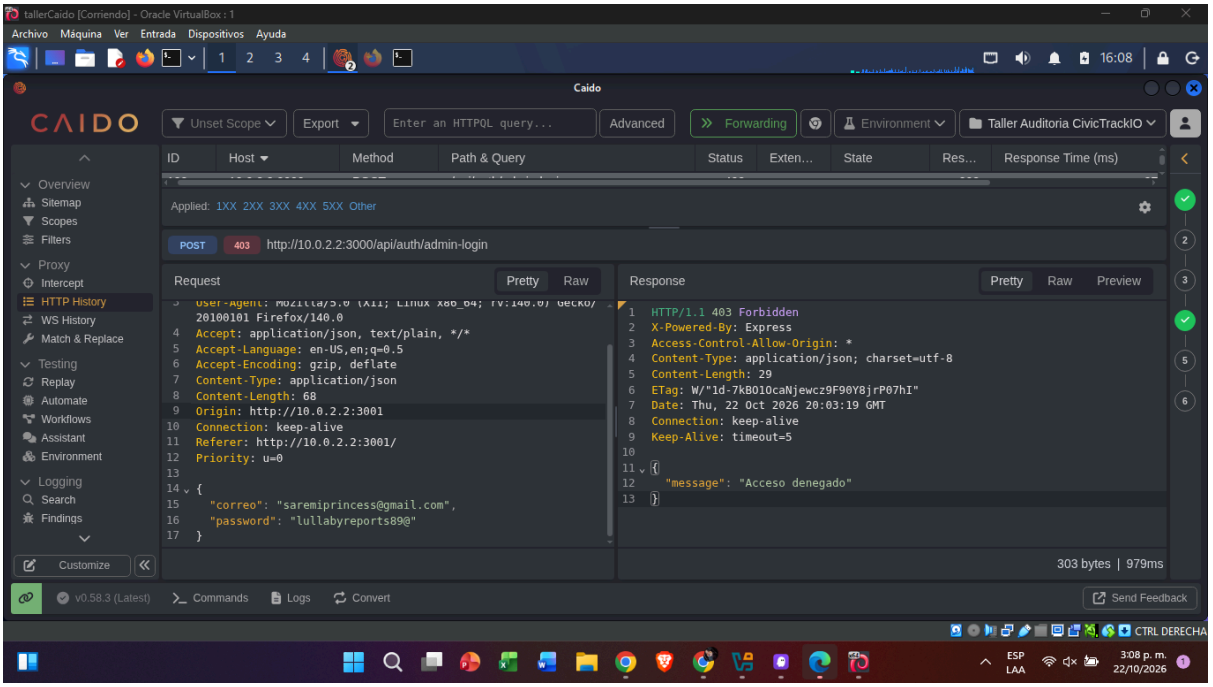




Ahora veremos cómo se comporta cuando quitamos la credencial de la petición, a comparación del anterior, retiramos la línea de ***Authorization***.



Cuando iniciamos sesión con un correo tipo usuario visualiza el acceso denegado.

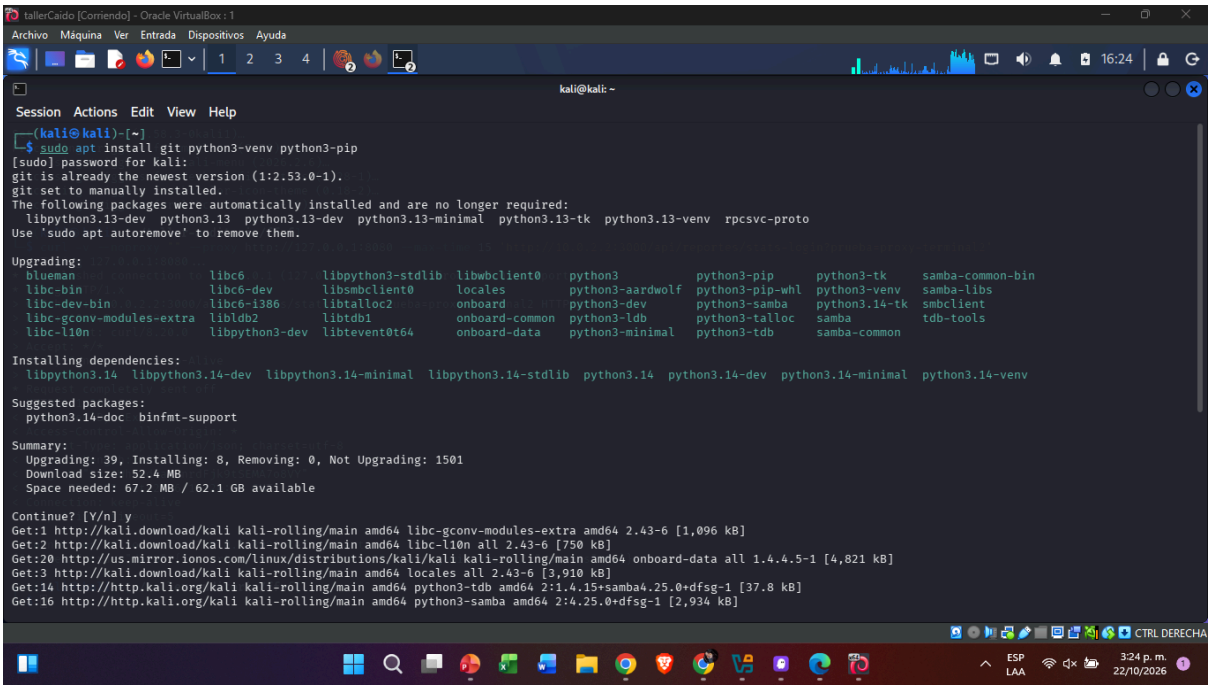


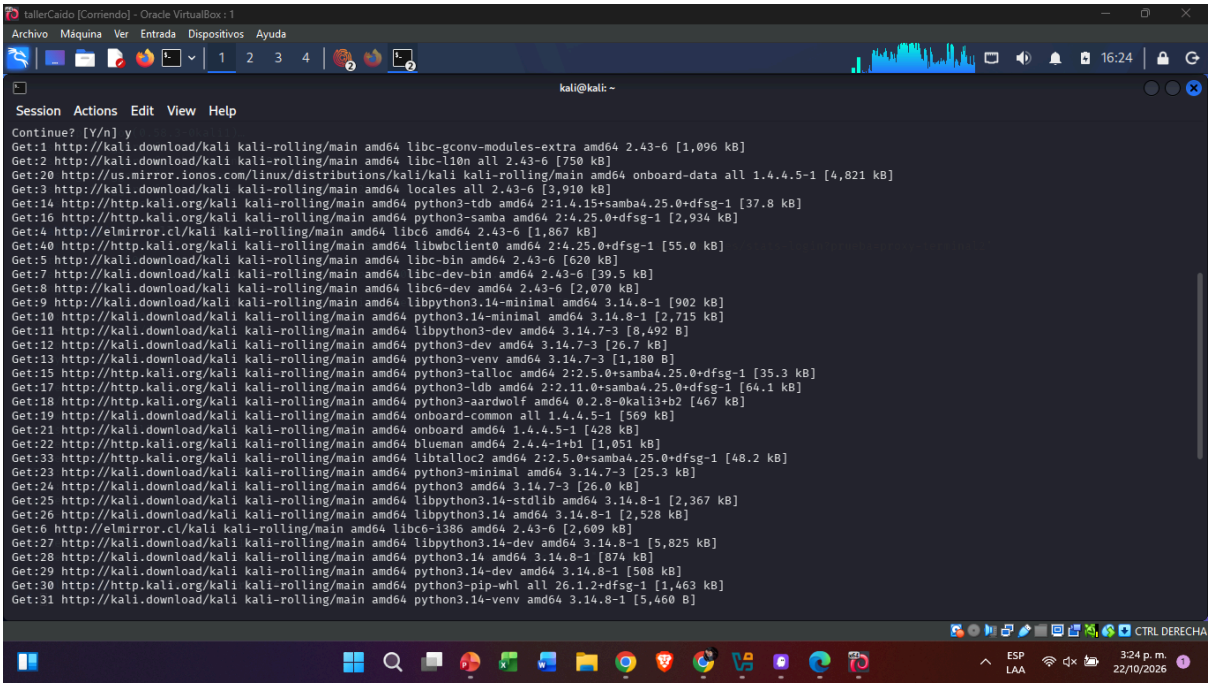
Con esto podemos visualizar que aún con pruebas o ediciones no hay un acceso o posibilidad de ingreso hasta este punto.

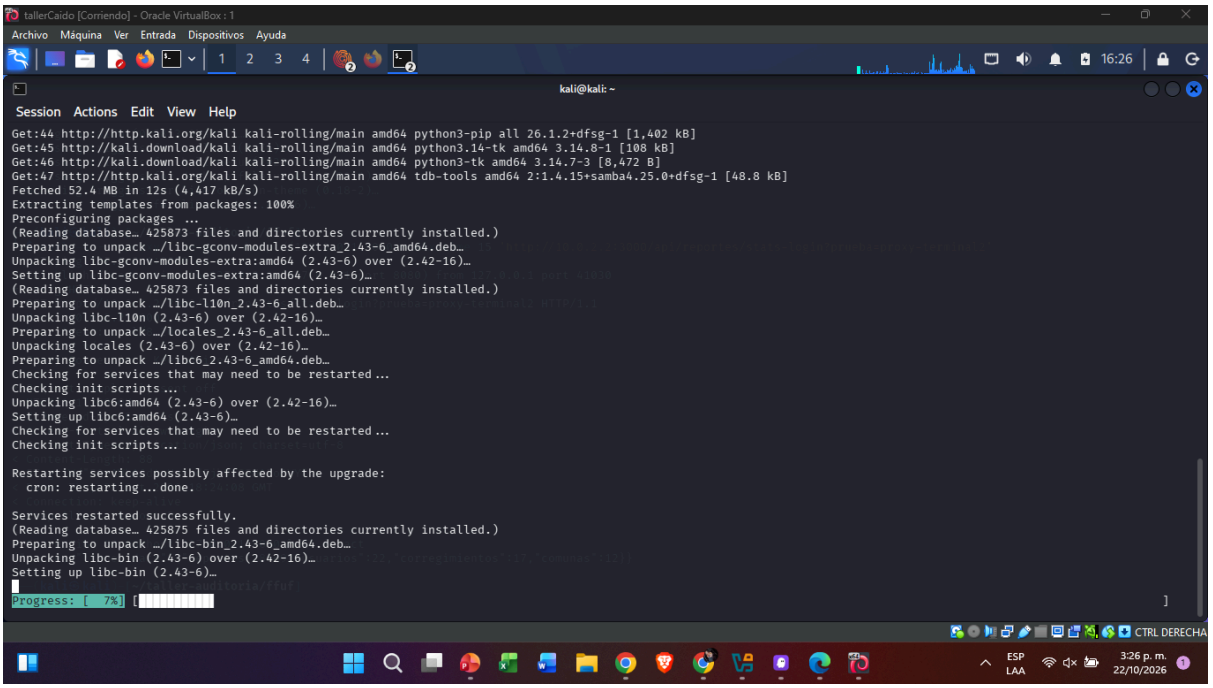
ID	Nombre de la prueba	Procedimiento	Resultado esperado	Resultado observado	Conclusión
C-01	Consulta del listado de usuarios con sesión administradora	Se reenvió en Replay una solicitud de consulta conservando la credencial de la sesión administradora	Permitir la consulta a la cuenta autorizada	200 OK. Respuesta JSON con success: true, listado de usuarios y metadatos de paginación	La sesión administradora utilizada pudo consultar el recurso
C-02	Consulta del listado de usuarios sin credenciales	Se repitió la solicitud anterior retirando las credenciales de autenticación	Rechazar la consulta y no entregar el listado	401 Unauthorized. Respuesta: {"message":"Token requerido"}	El servidor rechazó la solicitud sin token y no entregó los registros

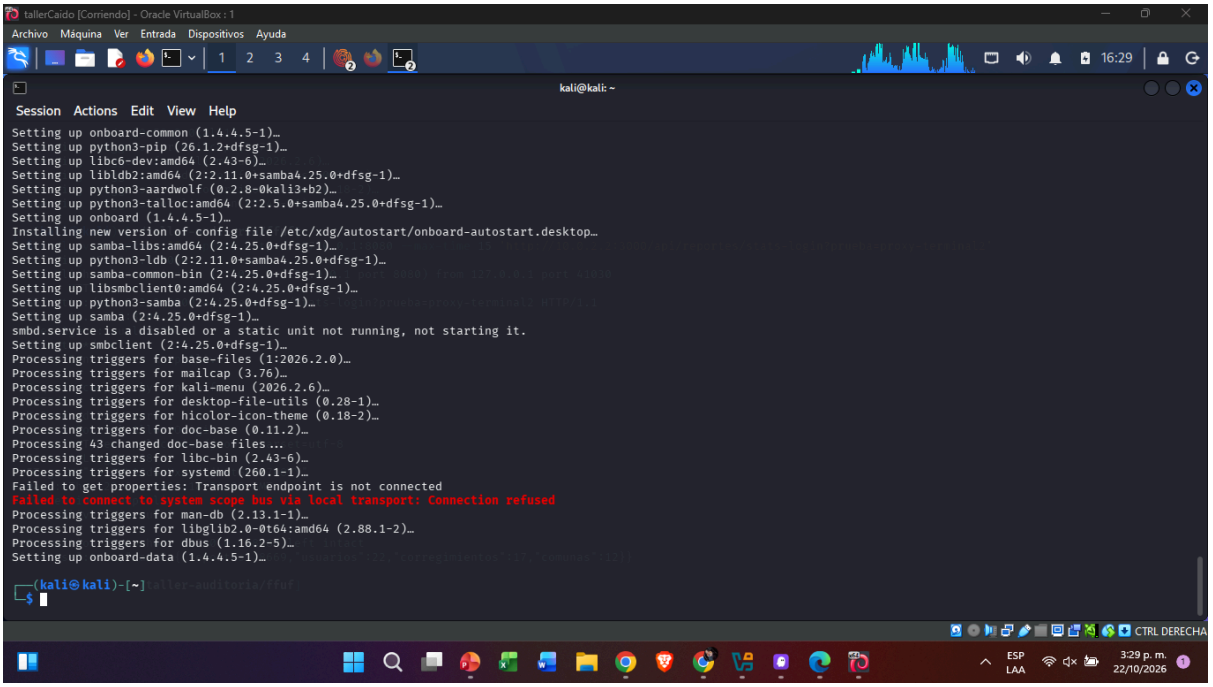
C-03	Intento de inicio de sesión administrativo con cuenta normal	Se enviaron desde el formulario administrativo las credenciales de una cuenta ficticia con rol usuario	Impedir el acceso al dashboard administrativo	403 Forbidden. Respuesta: {"message":"Acceso denegado"}	El servidor rechazó el intento de acceso administrativo con la cuenta normal evaluada

Ahora para el paso al punto del uso de JWT Tool tenemos que instalar las herramientas:

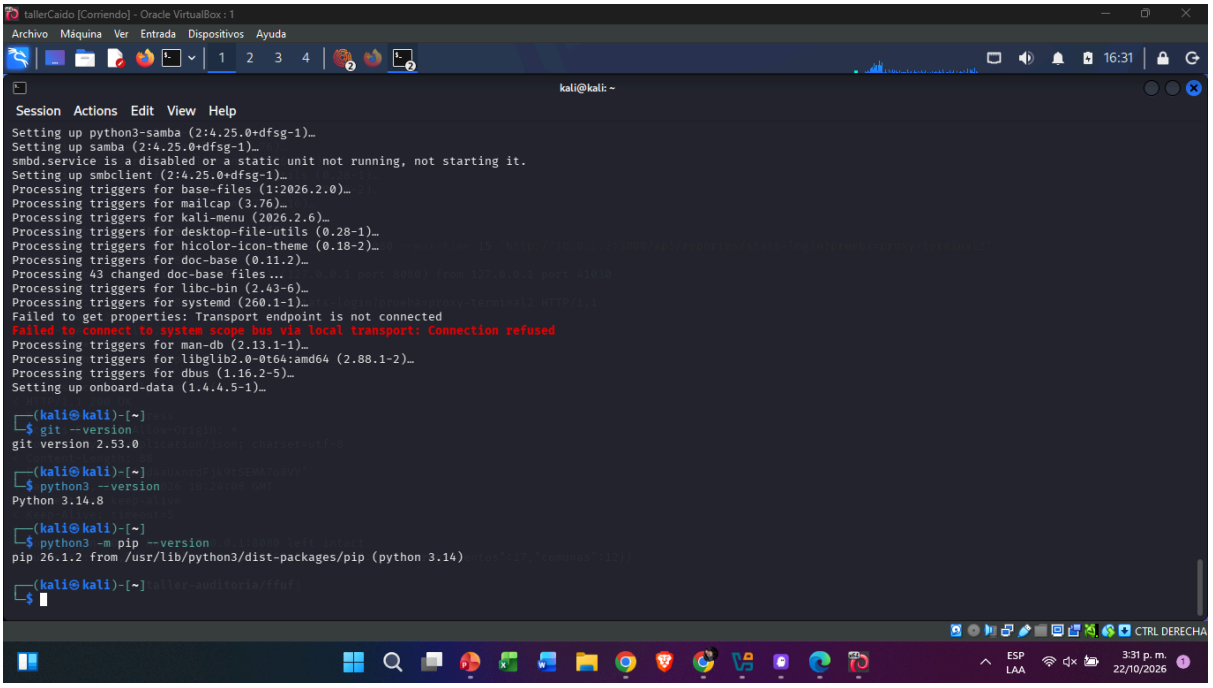



tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
16:24
kali@kali: ~
Session Actions Edit View Help
Continue? [Y/n] y
Get:1 http://kali.download/kali kali-rolling/main amd64 libc-gconv-modules-extra amd64 2.43-6 [1,096 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 libc-l10n all 2.43-6 [750 kB]
Get:20 http://us.mirror.ionos.com/linux/distributions/kali/kali kali-rolling/main amd64 onboard-data all 1.4.4.5-1 [4,821 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 locales all 2.43-6 [3,910 kB]
Get:14 http://http.kali.org/kali kali-rolling/main amd64 python3-tdb amd64 2:1.4.15+samba4.25.0+dfsg-1 [37.8 kB]
Get:16 http://http.kali.org/kali kali-rolling/main amd64 python3-samba amd64 2:4.25.0+dfsg-1 [2,934 kB]
Get:4 http://elmirror.cl/kali kali-rolling/main amd64 libc6 amd64 2.43-6 [1,867 kB]
Get:40 http://http.kali.org/kali kali-rolling/main amd64 libwbclient0 amd64 2:4.25.0+dfsg-1 [55.0 kB]
Get:5 http://kali.download/kali kali-rolling/main amd64 libc-bin amd64 2.43-6 [620 kB]
Get:7 http://kali.download/kali kali-rolling/main amd64 libc-dev-bin amd64 2.43-6 [39.5 kB]
Get:8 http://kali.download/kali kali-rolling/main amd64 libc6-dev amd64 2.43-6 [2,070 kB]
Get:9 http://kali.download/kali kali-rolling/main amd64 libpython3.14-minimal amd64 3.14.8-1 [902 kB]
Get:10 http://kali.download/kali kali-rolling/main amd64 python3.14-minimal amd64 3.14.8-1 [2,715 kB]
Get:11 http://kali.download/kali kali-rolling/main amd64 libpython3-dev amd64 3.14.7-3 [8,492 B]
Get:12 http://kali.download/kali kali-rolling/main amd64 python3-dev amd64 3.14.7-3 [26.7 kB]
Get:13 http://kali.download/kali kali-rolling/main amd64 python3-venv amd64 3.14.7-3 [1,180 B]
Get:15 http://http.kali.org/kali kali-rolling/main amd64 python3-talloc amd64 2:2.5.0+samba4.25.0+dfsg-1 [35.3 kB]
Get:17 http://http.kali.org/kali kali-rolling/main amd64 python3-ldb amd64 2:2.11.0+samba4.25.0+dfsg-1 [64.1 kB]
Get:18 http://http.kali.org/kali kali-rolling/main amd64 python3-aardwolf amd64 0.2.8-0kali3+b2 [467 kB]
Get:19 http://kali.download/kali kali-rolling/main amd64 onboard-common all 1.4.4.5-1 [569 kB]
Get:21 http://kali.download/kali kali-rolling/main amd64 onboard amd64 1.4.4.5-1 [428 kB]
Get:22 http://http.kali.org/kali kali-rolling/main amd64 blueman amd64 2.4.4-1+b1 [1,051 kB]
Get:33 http://http.kali.org/kali kali-rolling/main amd64 libtalloc2 amd64 2:2.5.0+samba4.25.0+dfsg-1 [48.2 kB]
Get:23 http://kali.download/kali kali-rolling/main amd64 python3-minimal amd64 3.14.7-3 [25.3 kB]
Get:24 http://kali.download/kali kali-rolling/main amd64 python3 amd64 3.14.7-3 [26.0 kB]
Get:25 http://kali.download/kali kali-rolling/main amd64 libpython3.14-stdlib amd64 3.14.8-1 [2,367 kB]
Get:26 http://kali.download/kali kali-rolling/main amd64 libpython3.14 amd64 3.14.8-1 [2,528 kB]
Get:6 http://elmirror.cl/kali kali-rolling/main amd64 libc6-i386 amd64 2.43-6 [2,609 kB]
Get:27 http://kali.download/kali kali-rolling/main amd64 libpython3.14-dev amd64 3.14.8-1 [5,825 kB]
Get:28 http://kali.download/kali kali-rolling/main amd64 python3.14 amd64 3.14.8-1 [874 kB]
Get:29 http://kali.download/kali kali-rolling/main amd64 python3.14-dev amd64 3.14.8-1 [508 kB]
Get:30 http://http.kali.org/kali kali-rolling/main amd64 python3-pip-whl all 26.1.2+dfsg-1 [1,463 kB]
Get:31 http://kali.download/kali kali-rolling/main amd64 python3.14-venv amd64 3.14.8-1 [5,460 B]
CTRL DERECHA
ESP
LAA
3:24 p. m.
22/10/2026

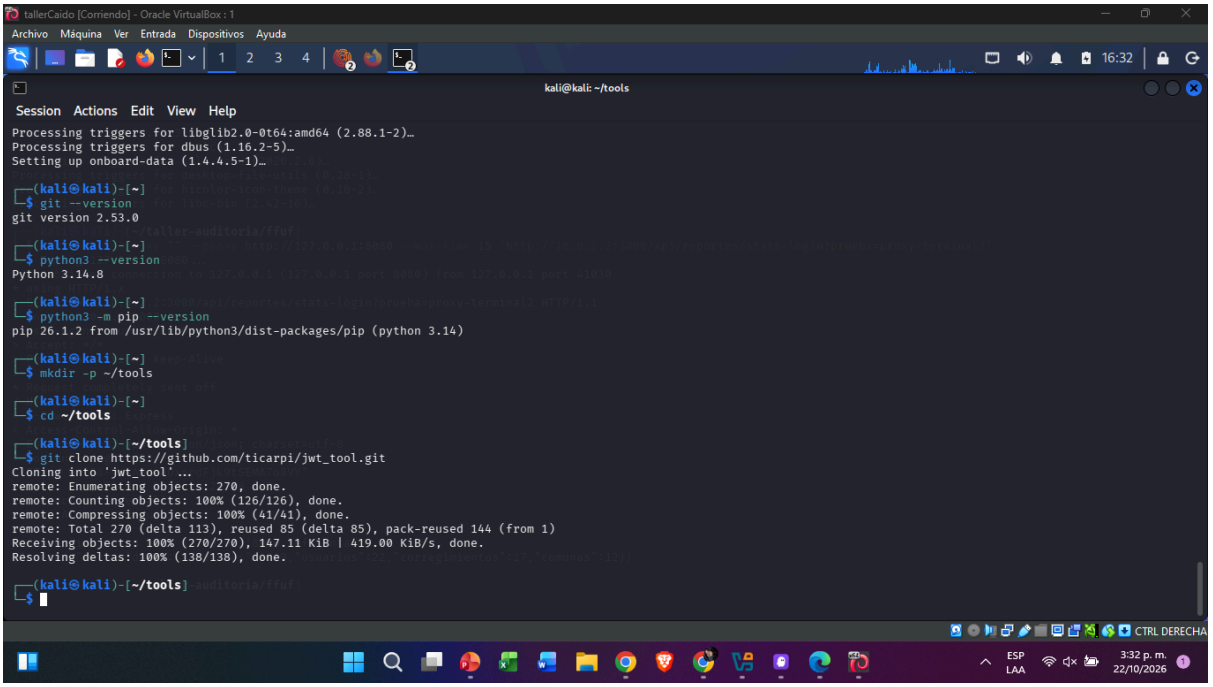

tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
16:26
kali@kali: ~
Session Actions Edit View Help
Get:44 http://http.kali.org/kali kali-rolling/main amd64 python3-pip all 26.1.2+dfsg-1 [1,402 kB]
Get:45 http://kali.download/kali kali-rolling/main amd64 python3.14-tk amd64 3.14.8-1 [108 kB]
Get:46 http://kali.download/kali kali-rolling/main amd64 python3-tk amd64 3.14.7-3 [8,472 B]
Get:47 http://http.kali.org/kali kali-rolling/main amd64 tdb-tools amd64 2:1.4.15+samba4.25.0+dfsg-1 [48.8 kB]
Fetched 52.4 MB in 12s (4,417 kB/s)
Extracting templates from packages: 100%
Preconfiguring packages ...
(Reading database… 425873 files and directories currently installed.)
Preparing to unpack …/libc-gconv-modules-extra_2.43-6_amd64.deb…
Unpacking libc-gconv-modules-extra:amd64 (2.43-6) over (2.42-16)…
Setting up libc-gconv-modules-extra:amd64 (2.43-6)…
(Reading database… 425873 files and directories currently installed.)
Preparing to unpack …/libc-l10n_2.43-6_all.deb…
Unpacking libc-l10n (2.43-6) over (2.42-16)…
Preparing to unpack …/locales_2.43-6_all.deb…
Unpacking locales (2.43-6) over (2.42-16)…
Preparing to unpack …/libc6_2.43-6_amd64.deb…
Checking for services that may need to be restarted…
Checking init scripts…
Unpacking libc6:amd64 (2.43-6) over (2.42-16)…
Setting up libc6:amd64 (2.43-6)…
Checking for services that may need to be restarted…
Checking init scripts…
Restarting services possibly affected by the upgrade:
cron: restarting… done.
Services restarted successfully.
(Reading database… 425875 files and directories currently installed.)
Preparing to unpack …/libc-bin_2.43-6_amd64.deb…
Unpacking libc-bin (2.43-6) over (2.42-16)…
Setting up libc-bin (2.43-6)…
Progress: [7%] [
]
CTRL DERECHA
ESP
LAA
3:26 p. m.
22/10/2026



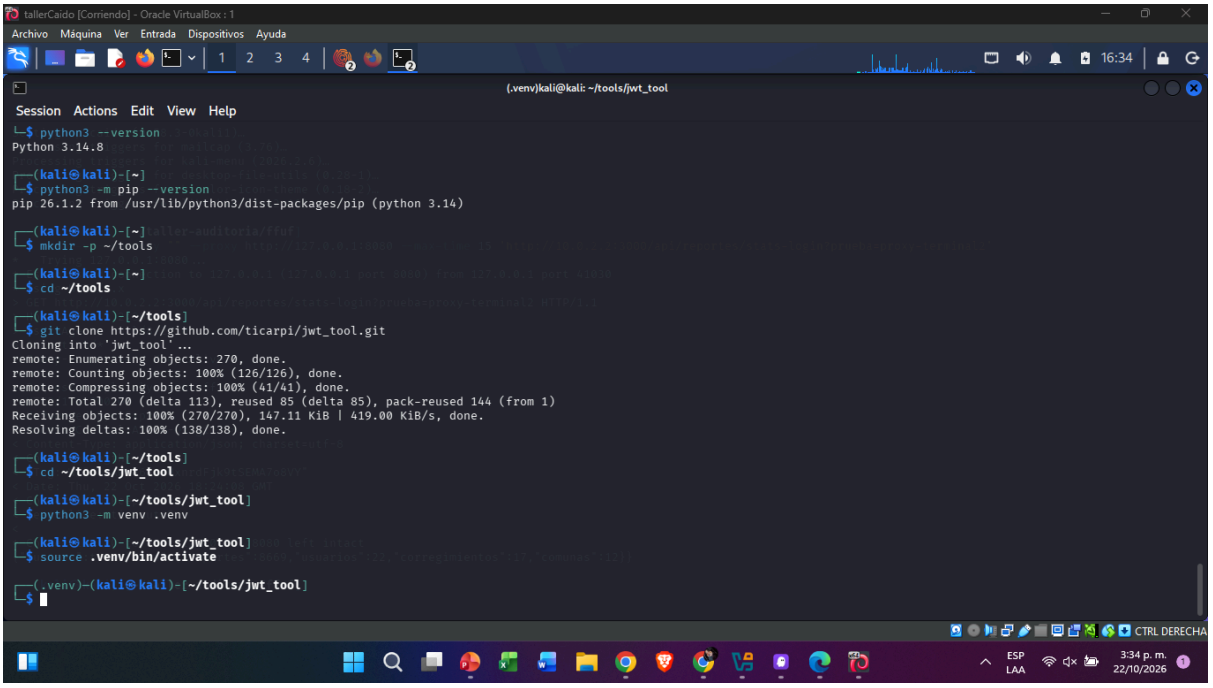
Comprobamos que se haya descargado todo correctamente.



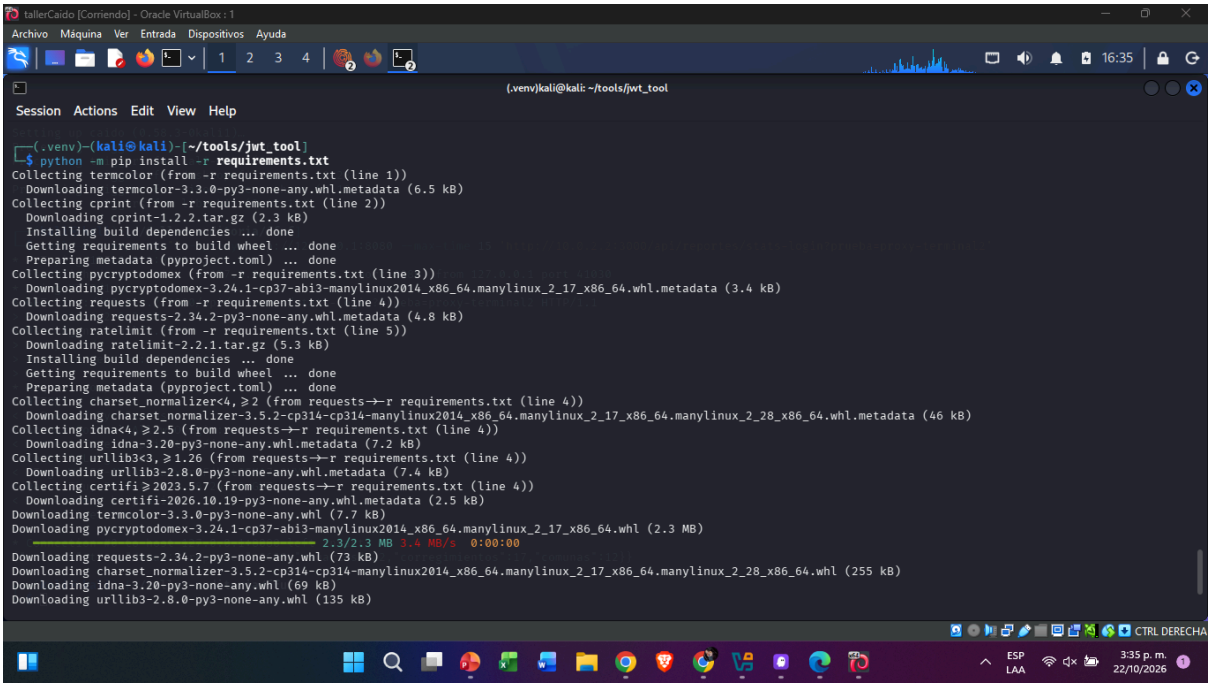
Descargamos o clonamos JWT Tool.

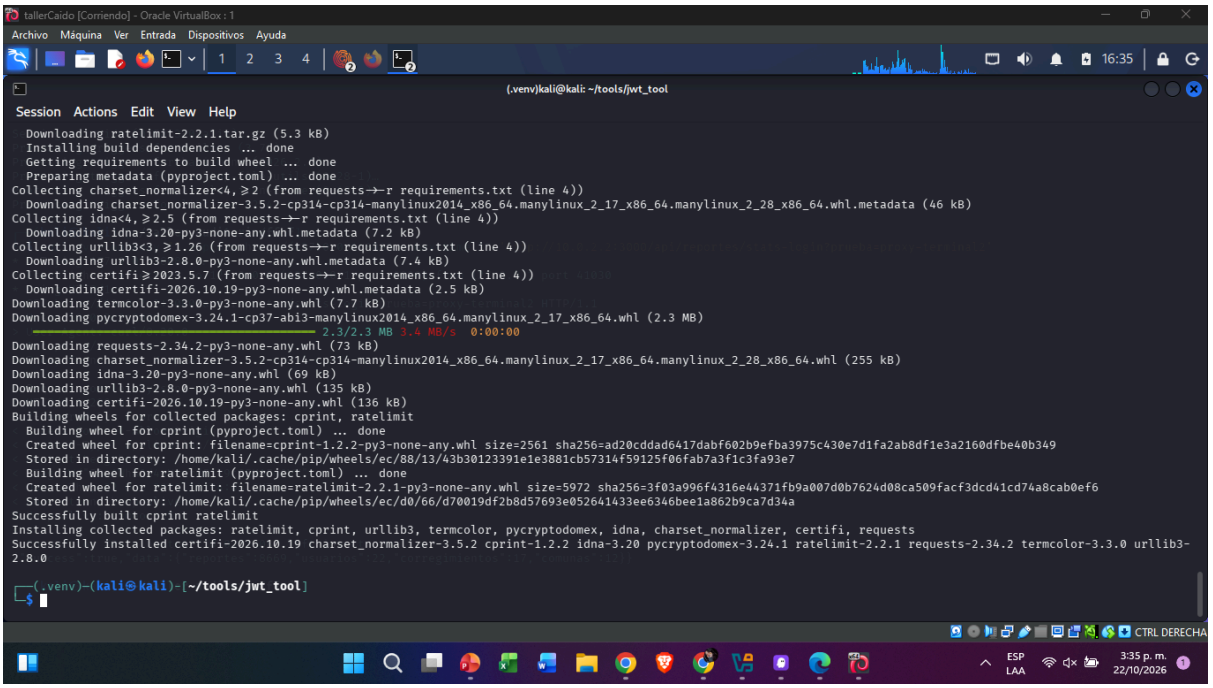


Ahora entramos en la carpeta y creamos el entorno visual.

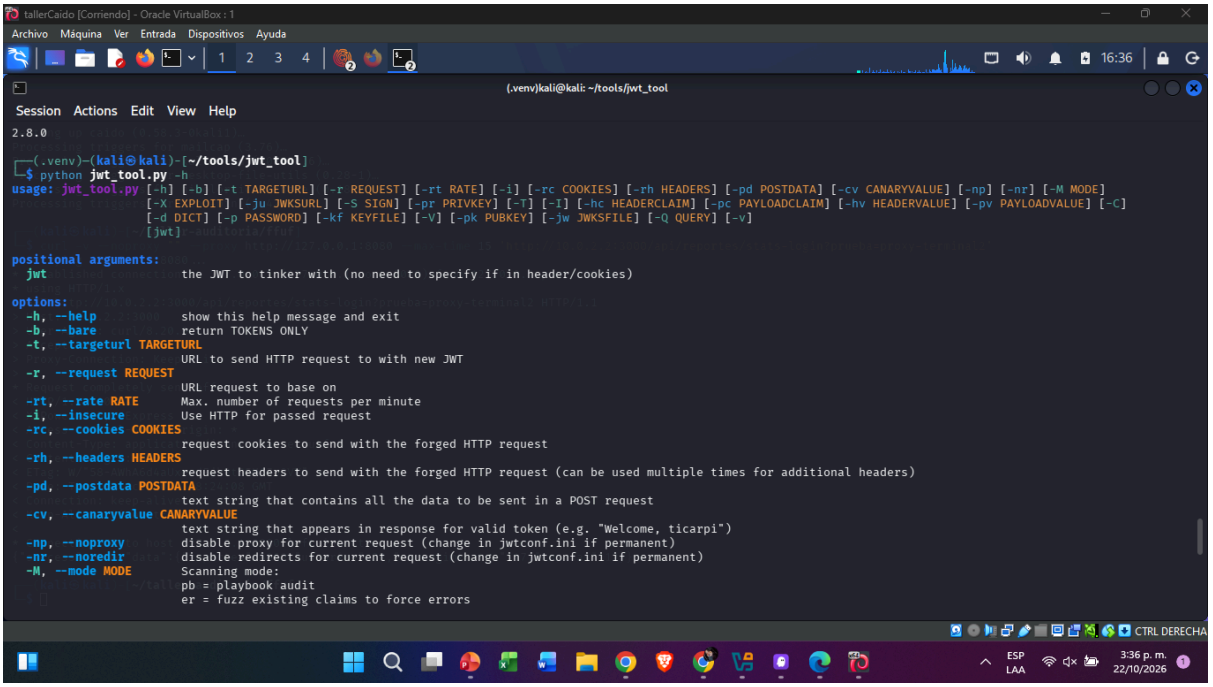


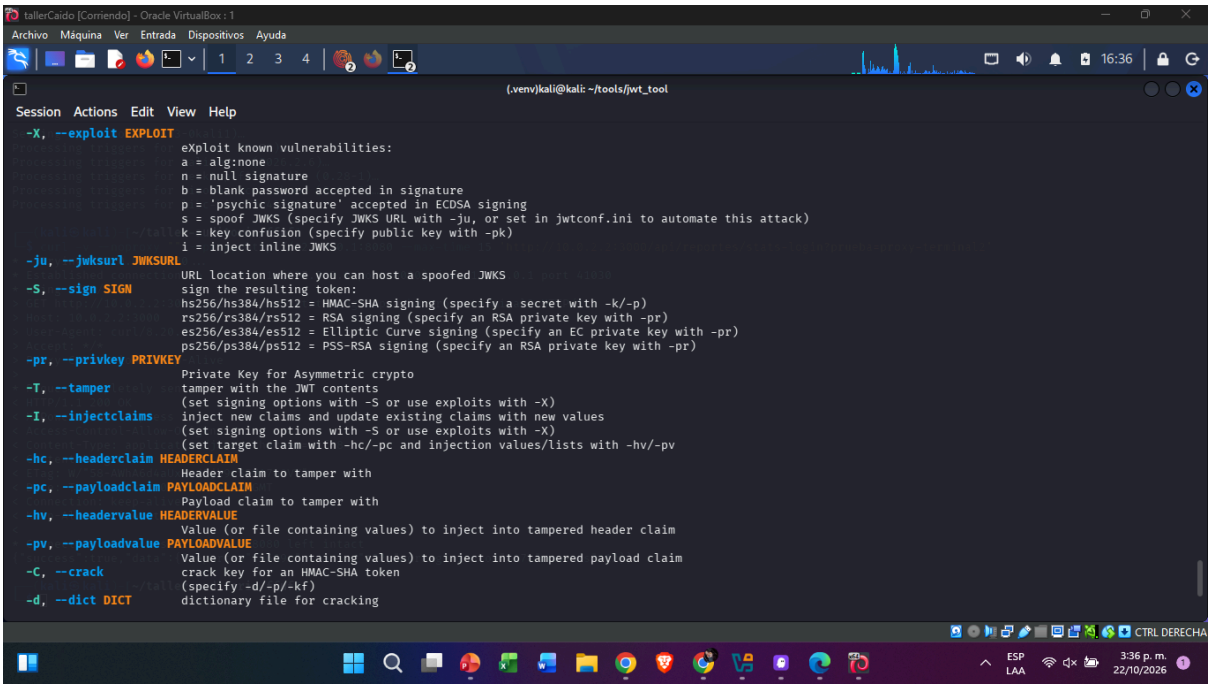
Instalamos las dependencias.

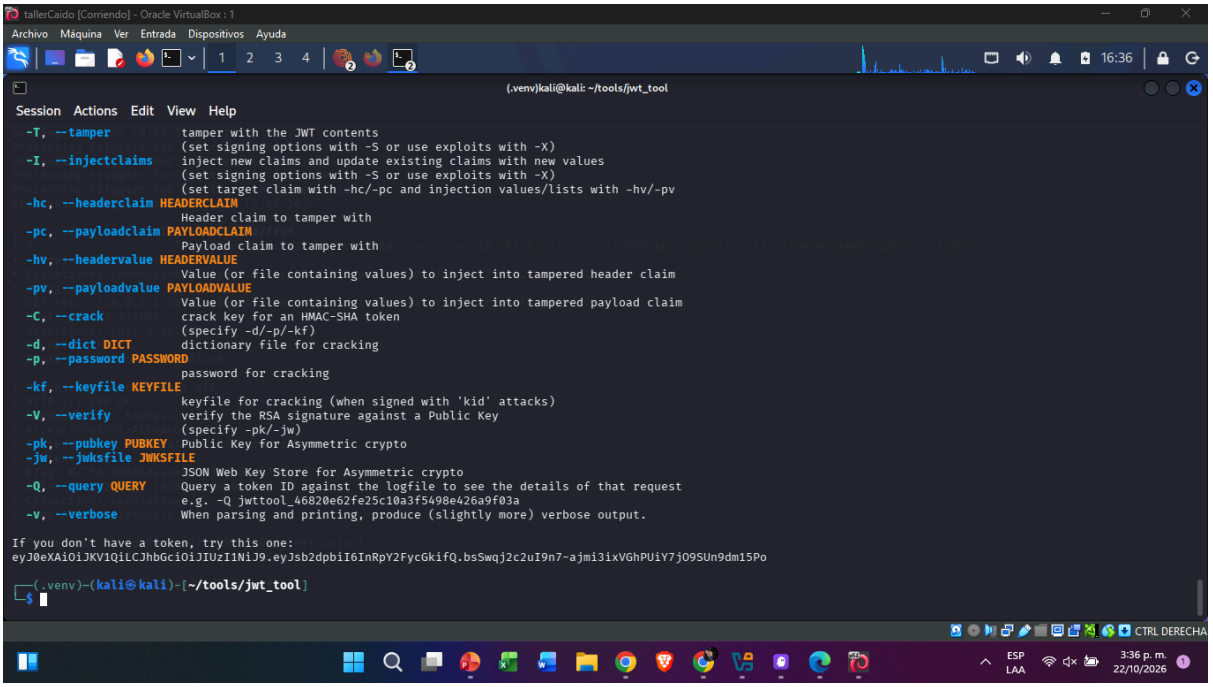




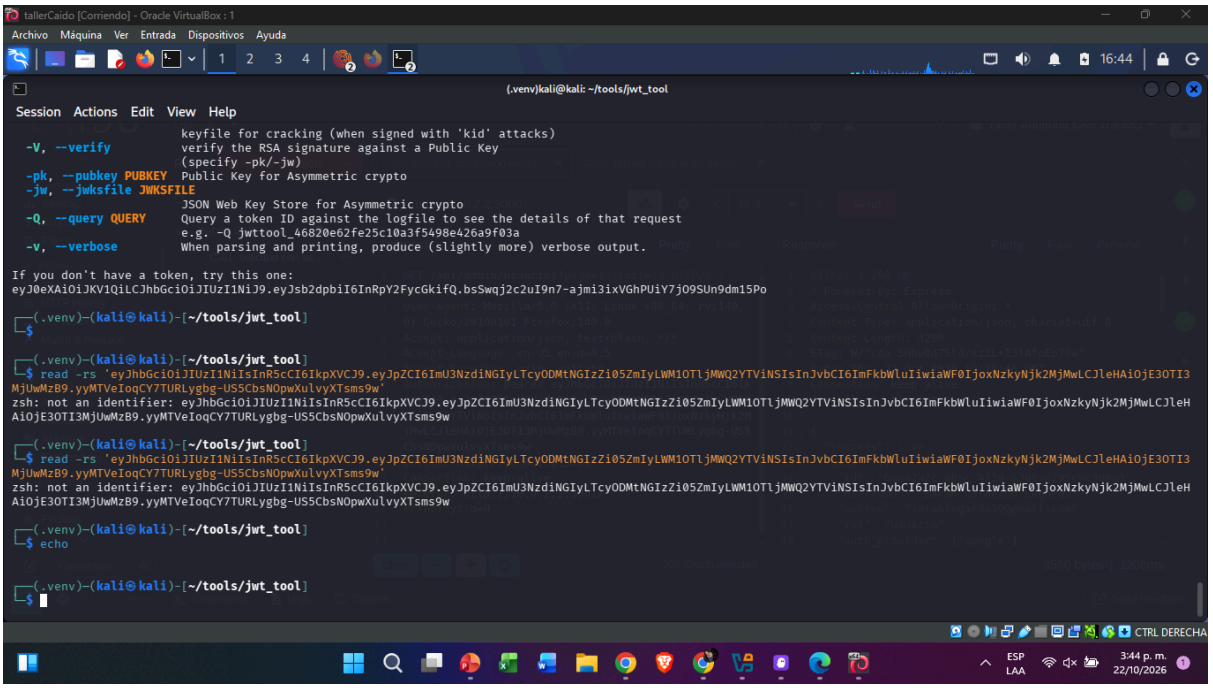
Comprobamos que JWT Tool abre.


tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
16:36
(.venv)kali@kali: ~/tools/jwt_tool
Session Actions Edit View Help
2.8.0
(.venv)-(kali㉿kali)-[~/tools/jwt_tool]
$ python jwt_tool.py -h
usage: jwt_tool.py [-h] [-b] [-t TARGETURL] [-r REQUEST] [-rt RATE] [-i] [-rc COOKIES] [-rh HEADERS] [-pd POSTDATA] [-cv CANARYVALUE] [-np] [-nr] [-M MODE]
[-X EXPLOIT] [-ju JWKSURL] [-S SIGN] [-pr PRIVKEY] [-T] [-I] [-hc HEADERCLAIM] [-pc PAYLOADCLAIM] [-hv HEADERVALUE] [-pv PAYLOADVALUE] [-C]
[-d DICT] [-p PASSWORD] [-kf KEYFILE] [-V] [-pk PUBKEY] [-jw JWKSFILE] [-Q QUERY] [-v]
[jwt]
positional arguments:
jwt the JWT to tinker with (no need to specify if in header/cookies)
options:
-h, --help show this help message and exit
-b, --bare return TOKENS ONLY
-t, --targeturl TARGETURL
URL to send HTTP request to with new JWT
-r, --request REQUEST
URL request to base on
-rt, --rate RATE Max. number of requests per minute
-i, --insecure Use HTTP for passed request
-rc, --cookies COOKIES
request cookies to send with the forged HTTP request
-rh, --headers HEADERS
request headers to send with the forged HTTP request (can be used multiple times for additional headers)
-pd, --postdata POSTDATA
text string that contains all the data to be sent in a POST request
-cv, --canaryvalue CANARYVALUE
text string that appears in response for valid token (e.g. "Welcome, ticarpi")
-np, --noproxy disable proxy for current request (change in jwtconf.ini if permanent)
-nr, --noredir disable redirects for current request (change in jwtconf.ini if permanent)
-M, --mode MODE Scanning mode:
pb = playbook audit
er = fuzz existing claims to force errors
CTRL DERECHA
ESP
LAA
3:36 p. m.
22/10/2026

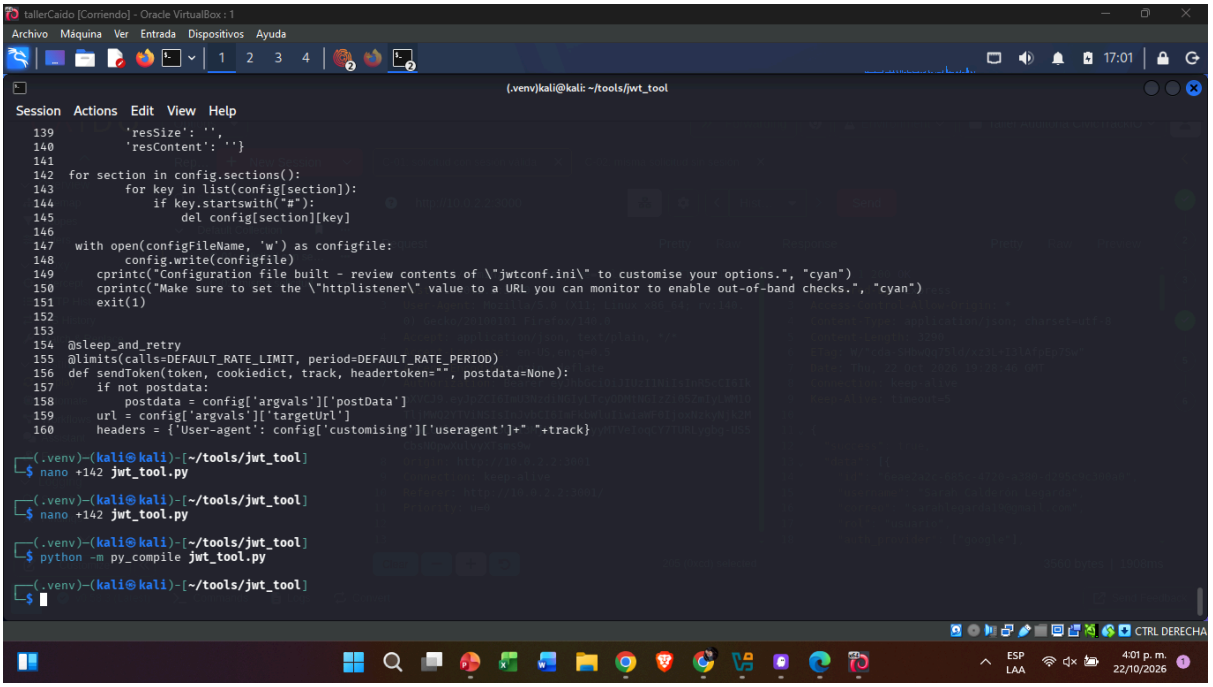

tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
16:36
(.venv)kali@kali: ~/tools/jwt_tool
Session Actions Edit View Help
-X, --exploit EXPLOIT
eXploit known vulnerabilities:
a = alg:none
n = null signature
b = blank password accepted in signature
p = 'psychic signature' accepted in ECDSA signing
s = spoof JWKS (specify JWKS URL with -ju, or set in jwtconf.ini to automate this attack)
k = key confusion (specify public key with -pk)
i = inject inline JWKS
-ju, --jwksurl JWKSURL
URL location where you can host a spoofed JWKS
-S, --sign SIGN sign the resulting token:
hs256/hs384/hs512 = HMAC-SHA signing (specify a secret with -k/-p)
rs256/rs384/rs512 = RSA signing (specify an RSA private key with -pr)
es256/es384/es512 = Elliptic Curve signing (specify an EC private key with -pr)
ps256/ps384/ps512 = PSS-RSA signing (specify an RSA private key with -pr)
-pr, --privkey PRIVKEY
Private Key for Asymmetric crypto
-T, --tamper tamper with the JWT contents
(set signing options with -S or use exploits with -X)
-I, --injectclaims inject new claims and update existing claims with new values
(set signing options with -S or use exploits with -X)
(set target claim with -hc/-pc and injection values/lists with -hv/-pv
-hc, --headerclaim HEADERCLAIM
Header claim to tamper with
-pc, --payloadclaim PAYLOADCLAIM
Payload claim to tamper with
-hv, --headervalue HEADERVALUE
Value (or file containing values) to inject into tampered header claim
-pv, --payloadvalue PAYLOADVALUE
Value (or file containing values) to inject into tampered payload claim
-C, --crack crack key for an HMAC-SHA token
(specify -d/-p/-kf)
-d, --dict DICT dictionary file for cracking
CTRL DERECHA
ESP
LAA
3:36 p. m.
22/10/2026



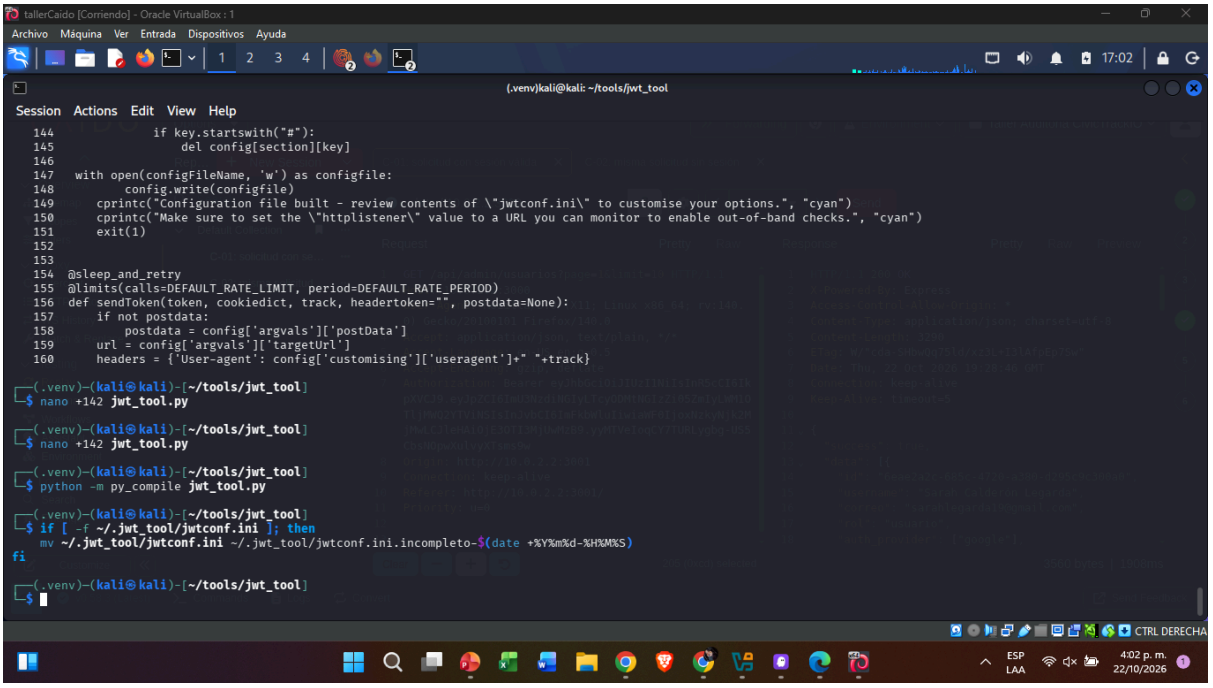
Ahora analizaremos un token de una cuenta ficticia del laboratorio. Por el momento, solo lo vamos a inspeccionar, sin modificarlo ni enviar pruebas automáticas.



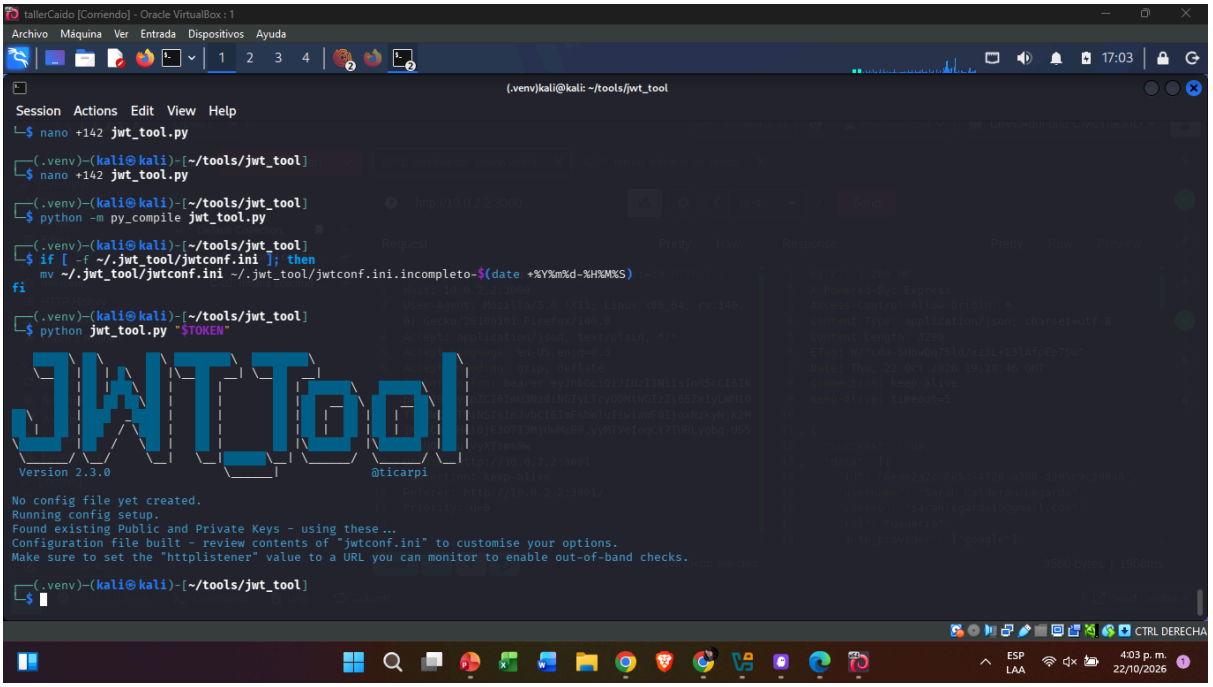
Ahora analizaremos la estructura.



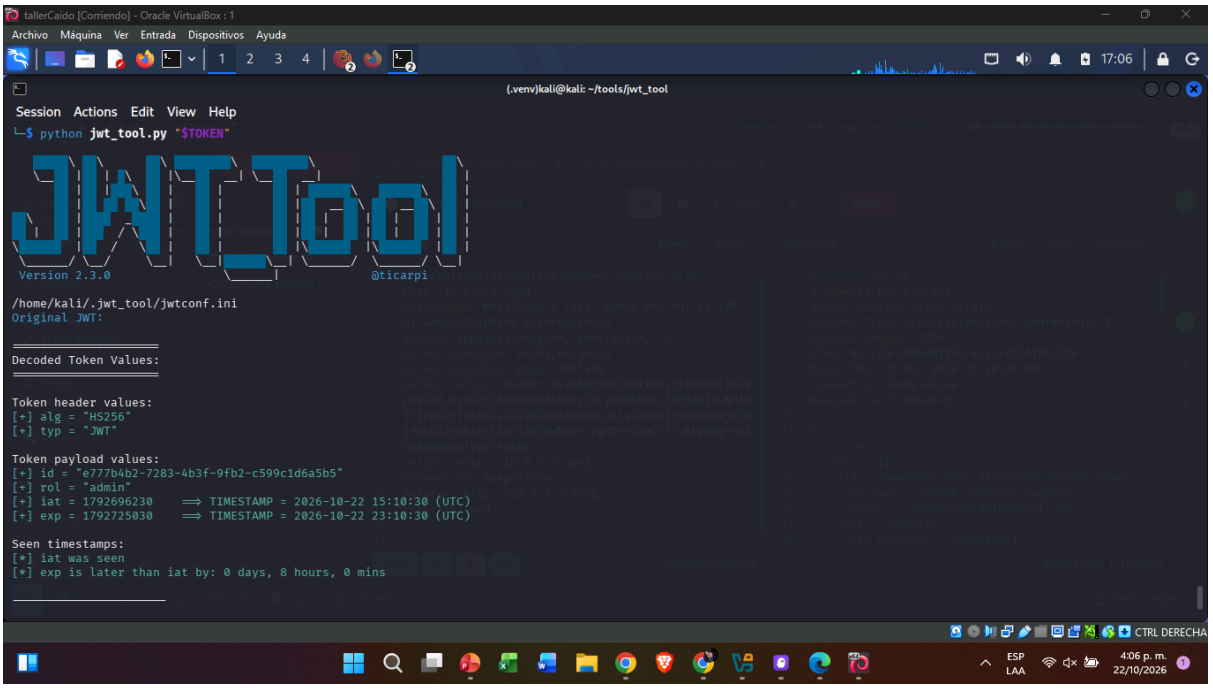
Apartamos la configuración incompleta.

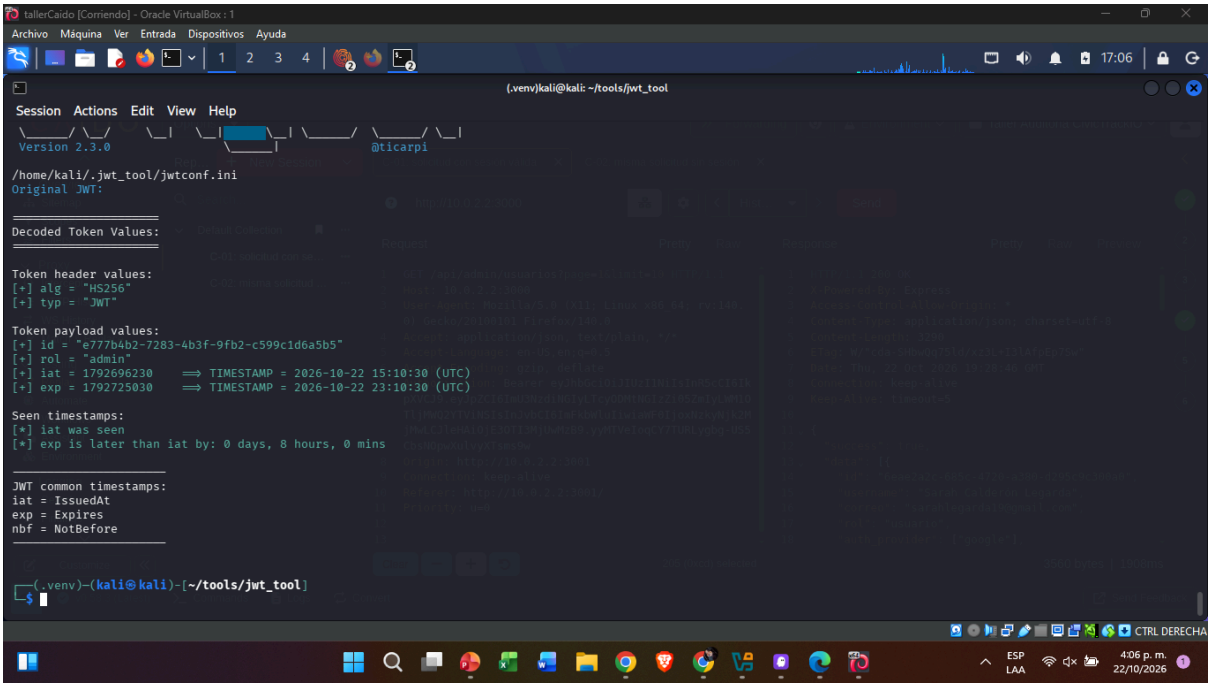


Y analizamos el token.



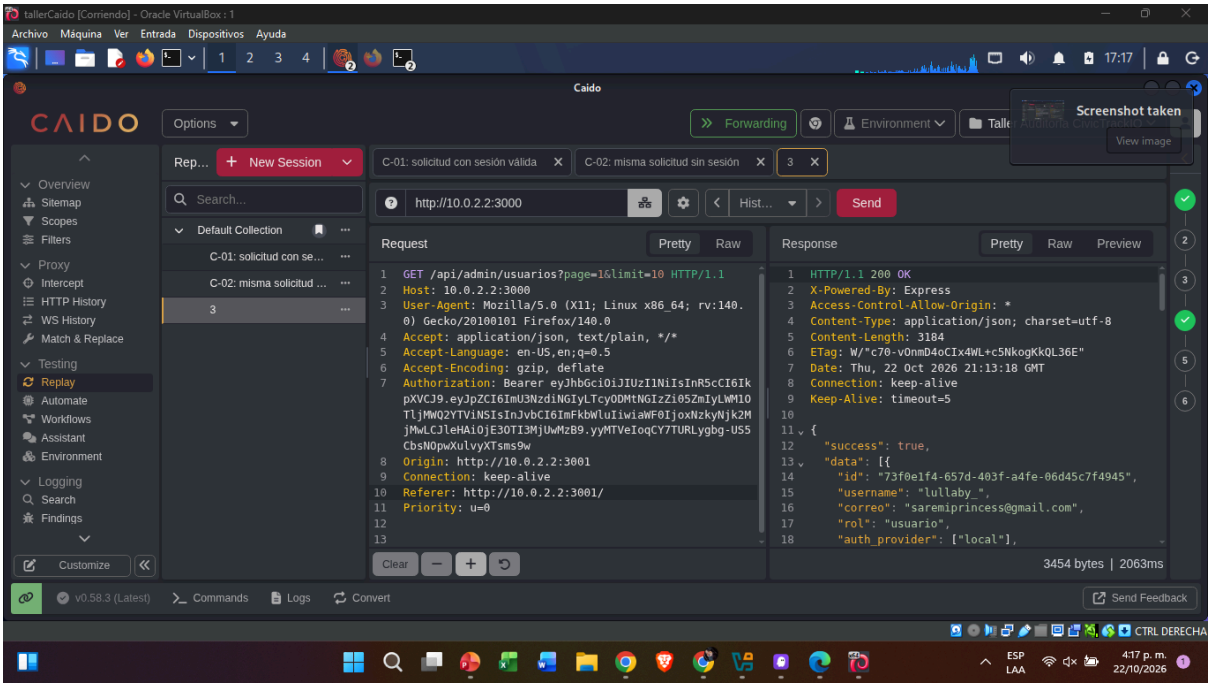
Como únicamente muestra que creó el archivo de configuración y termina, hacemos una ejecución nuevamente.



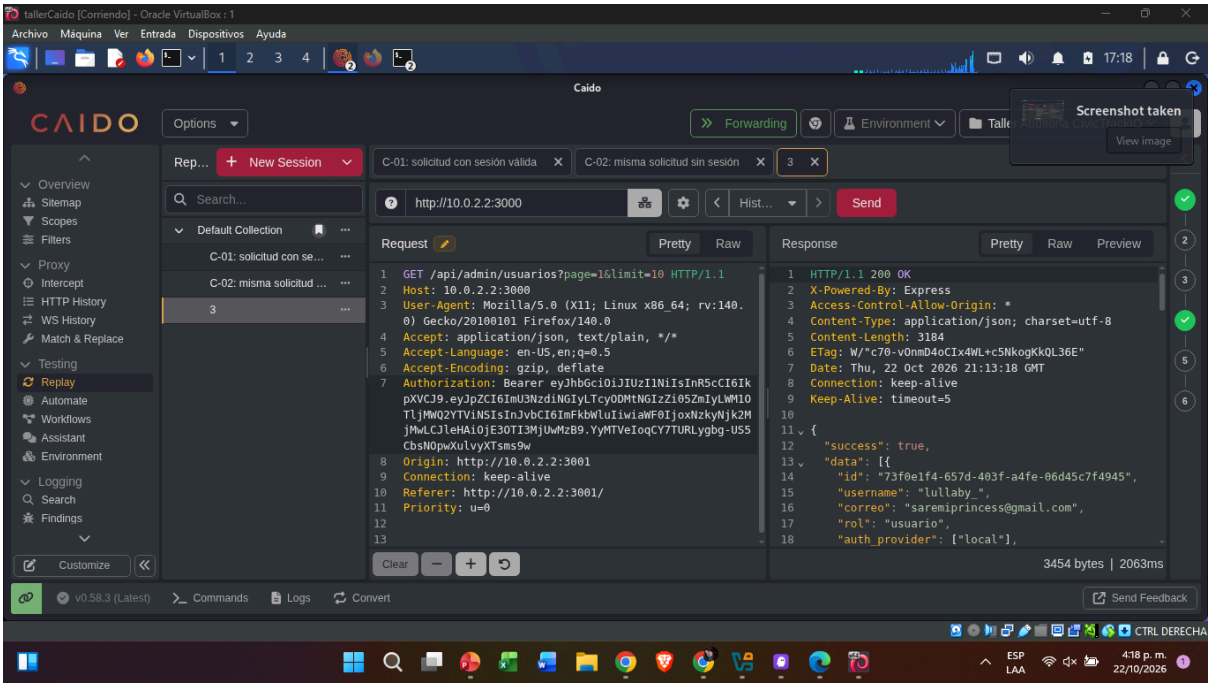


Ahora modificamos un carácter de la firma.

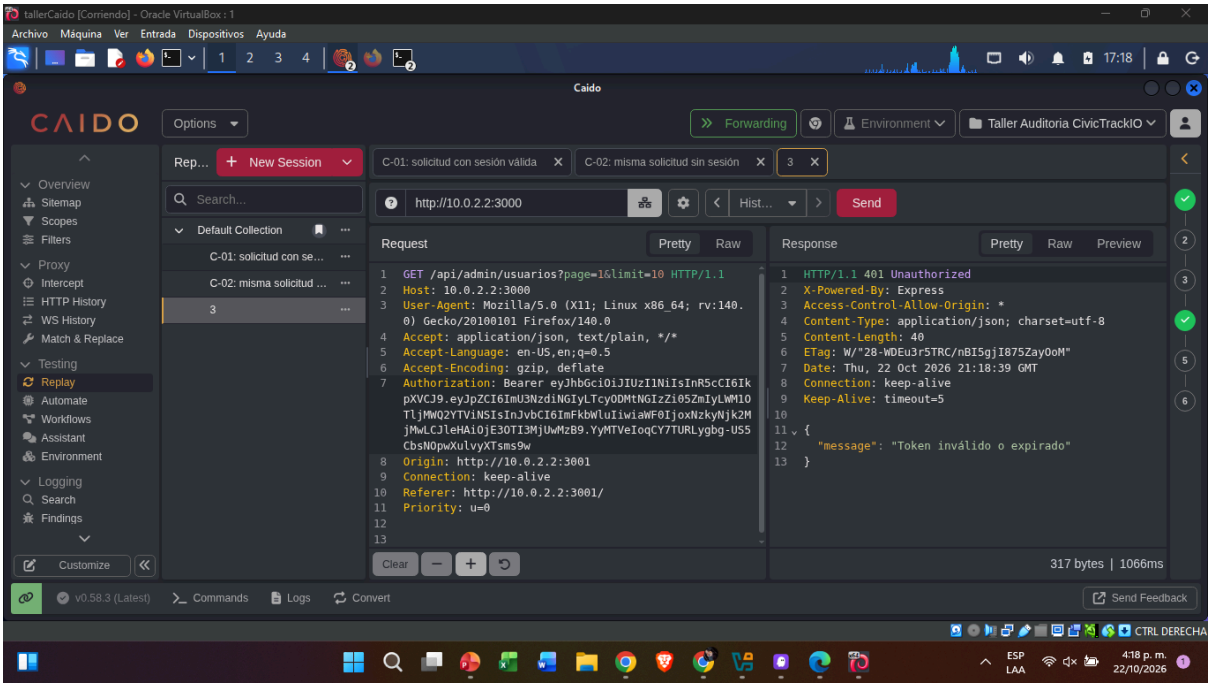
Estado del token original.



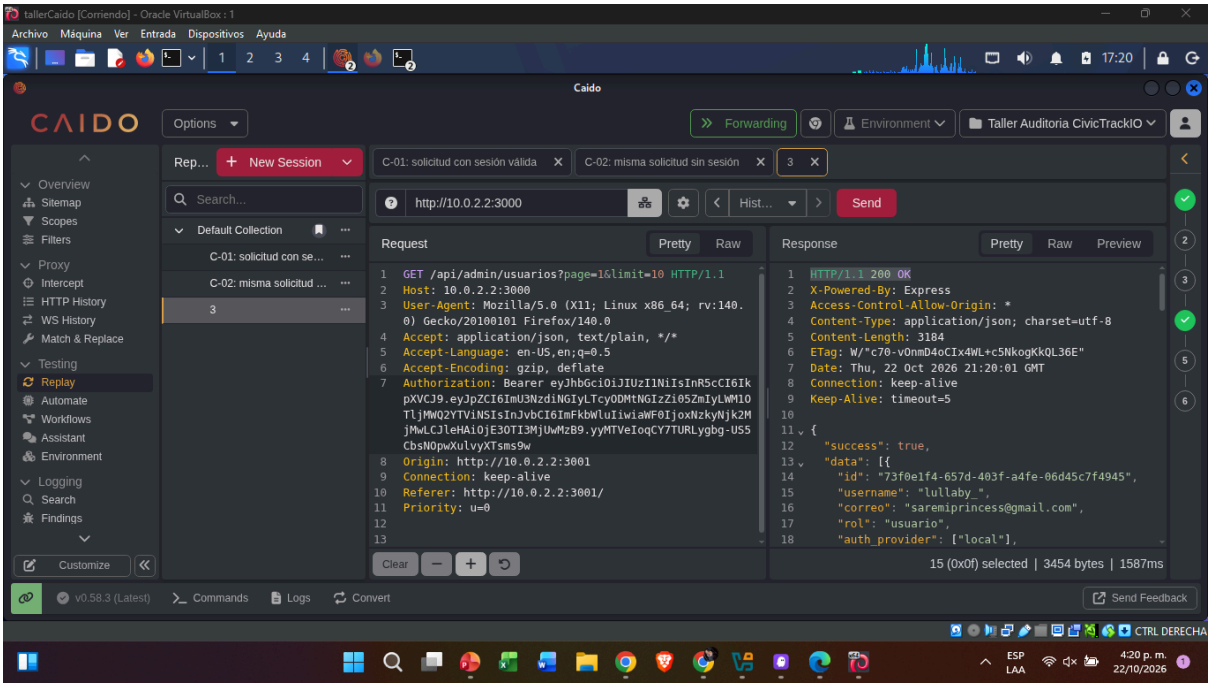
Token editado en la firma.



Respuesta a ese envío.



Restauramos al token inicial y nos debe permitir nuevamente el acceso.


tallerCaido [Corriendo] - Oracle VirtualBox : 1
Archivo Máquina Ver Entrada Dispositivos Ayuda
Caido
CAIDO
Options
Forwarding
Environment
Taller Auditoria CivicTrackIO
Rep...
New Session
C-01: solicitud con sesión válida
C-02: misma solicitud sin sesión
3
Overview
Sitemap
Scopes
Filters
Proxy
Intercept
HTTP History
WS History
Match & Replace
Testing
Replay
Automate
Workflows
Assistant
Environment
Logging
Search
Findings
Customize
Search...
Default Collection
C-01: solicitud con se...
C-02: misma solicitud ...
3
http://10.0.2.2:3000
Hist...
Send
Request
Pretty
Raw
GET /api/admin/usuarios?page=1&limit=10 HTTP/1.1
Host: 10.0.2.2:3000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImU3NzdiNGIyLTcyODMtNGIzZi05ZmIyLWM1OTljMWQ2YTViNSIsInJvbCI6ImFkbWluIiwiaWF0IjoxNzkyNjk2MjMwLCJleHAiOjE3OTI3MjUwMzB9.yyMTVeIoqCY7TURLygbg-US5CbsNOpwXulvyXTsms9w
Origin: http://10.0.2.2:3001
Connection: keep-alive
Referer: http://10.0.2.2:3001/
Priority: u=0
Clear
Response
Pretty
Raw
Preview
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 3184
ETag: W/"c70-vOnmD4oCIx4WL+c5NkogKkQL36E"
Date: Thu, 22 Oct 2026 21:20:01 GMT
Connection: keep-alive
Keep-Alive: timeout=5
{
"success": true,
"data": [{
"id": "73f0e1f4-657d-403f-a4fe-06d45c7f4945",
"username": "lullaby_",
"correo": "saremiprincess@gmail.com",
"rol": "usuario",
"auth_provider": ["local"],
15 (0x0f) selected | 3454 bytes | 1587ms
v0.58.3 (Latest)
Commands
Logs
Convert
Send Feedback
CTRL DERECHA
ESP
LAA
4:20 p. m.
22/10/2026

Conclusiones

1. El fuzzing con FFUF reveló una superficie de exposición moderada y bien controlada. De las 35 rutas probadas, solo dos devolvieron código 200 (/api/auth/terminos y /api/reportes/stats-login), y según la tabla de resultados, ninguna expuso credenciales, datos personales ni información sensible: la primera mostró contenido público (términos y política de privacidad) y la segunda, estadísticas agregadas sin identificar usuarios. El resto de rutas fueron correctamente rechazadas con 401 (token requerido), lo que indica que el control de autenticación a nivel de rutas protegidas funciona de forma consistente.

2. Los controles de autorización por rol (RBAC) en Caido se mostraron efectivos ante los tres escenarios probados. La tabla de pruebas C-01 a C-03 evidencia que: (a) una sesión administradora válida sí pudo consultar el listado de usuarios (200 OK), (b) la misma solicitud sin credenciales fue rechazada (401, “Token requerido”), y (c) un intento de iniciar sesión en el panel administrativo con una cuenta de rol “usuario” fue bloqueado (403, “Acceso denegado”). Esto confirma que el backend valida tanto la presencia del token como el rol asociado antes de autorizar operaciones sensibles, además debemos destacar que las pruebas se limitan al dashboard administrativo, entorno donde los usuarios de la aplicación no tienen acceso sin un correo previamente verificado y registrado por los demás administradores.

3. El sistema de validación de JWT resistió la manipulación básica de la firma. Al modificar manualmente un carácter de la firma del token con sesión válida y reenviarlo mediante Caido Replay, el servidor respondió con 401 (“Token inválido o expirado”), mientras que al restaurar el token original el acceso se recuperó (200 OK). Esto demuestra que el backend verifica correctamente la integridad criptográfica del JWT y no acepta tokens alterados, incluso con cambios mínimos.

4. El principal hallazgo pendiente no es una vulnerabilidad confirmada, sino una limitación metodológica a resolver. La comparación entre /api/reportes y la ruta de control deliberadamente inexistente (/api/reportes/ruta-inexistente-control) arrojó la misma respuesta 401 con idéntico mensaje, lo cual impide, usando solo ese método, distinguir si una ruta protegida realmente existe o no (ausencia de diferenciación en el comportamiento de error). Esto no constituye por sí mismo una falla de seguridad, pero señala la necesidad de pruebas adicionales con una sesión autenticada válida para caracterizar completamente los endpoints protegidos.